

Cyber - Lecture

Topic	Where to look
Ransomware / Big Game Hunting	Week 1
Snake malware / cyber espionage	Week 1
Disinformation / scams / hacker hats	Week 1
Human factors / social engineering	Week 2
Phishing / spear phishing / cyber vetting	Week 2
Cryptography goals: confidentiality, integrity, authenticity, non-repudiation	Week 3
Symmetric vs asymmetric encryption	Week 3
ECB vs CBC / block vs stream cipher	Week 3
RSA / digital signature / hash / TLS / salting	Week 3
CIA triad	Week 4
Security assessment types	Week 4
Black-box / white-box / manual / automated / static / dynamic	Week 4
Penetration testing phases	Week 4
Vulnerability scanning vs penetration testing	Week 4
CVE / NVD / CVSS / CWE	Week 4
Red team / blue team / purple team	Week 4
Threat intelligence types: strategic, operational, tactical	Week 5
SOC cycle	Week 5
IOC / MITRE ATT&CK	Week 5
SIEM / Splunk	Week 5
Essential 8	Week 5
Network sniffing / MITM	Week 7
ARP / ARP poisoning	Week 7
DHCP / DORA / DHCP attacks	Week 7
DoS / DDoS / SYN flood / Smurf / DNS amplification	Week 7

Topic	Where to look
DNS / DNS spoofing / DNSSEC	Week 7
WEP / WPA2 / WPA3	Week 7
Firewall / segmentation / microsegmentation	Week 7
IDS vs IPS	Week 7
URL / cookies / HTTP / 3-tier web app	Week 8
Burp / ZAP / proxy functions	Week 8
OWASP Top 10	Week 8
SQL injection / blind SQL injection / UNION / batched SQL	Week 8
Command injection	Week 8
Input validation / whitelisting / prepared statements	Week 8
DFIR / CIRT / forensic process	Week 9
Network forensics / PCAP / packet traces vs network logs	Week 9
Steganography / steganalysis	Week 9
Malware analysis / static vs dynamic analysis	Week 9
Reverse engineering / Ghidra / disassembler / decompiler / ABI	Week 9
Security engineering principles	Week 10
Least privilege / defence in depth / zero trust / fail securely	Week 10
Risk = threat + vulnerability / risk = impact × likelihood	Week 10
AV / EF / SLE / ARO / ALE	Week 10
Control types: admin / physical / technical	Week 10
Preventive / detective / corrective controls	Week 10
ISO 27001 / NIST CSF / CIS / Essential 8 / ISM	Week 10
Law vs ethics	Week 11
Privacy / cybercrime / spam / data breach / copyright laws	Week 11
Legal considerations in pen testing	Week 11
Teleology vs deontology / Ross' duties	Week 11

Topic	Where to look
GDPR rights / controller / processor / DPO / DPIA	Week 11

Week 1 Introduction

Why Cybersecurity is Important

- Increased reliance on digital systems
- Systems and people remain vulnerable
- Cybercrime is profitable and difficult to prosecute(难以追溯)
- High demand for cybersecurity professionals

Australian Cybersecurity Initiatives

- Australian Cyber Security Strategy 2023-2030
- Essential Eight
- Information Security Manual (ISM)
- Privacy Act 1988
- Online Safety Act 2021

Ransomware

- Fastest-growing cybercrime
- Encrypts data and demands payment
- Targets businesses and critical infrastructure
- "Big Game Hunting" = attackers target large organisations because they can pay larger ransoms

Why ransomware is dangerous:

- Loss of availability
- Financial losses
- Operational disruption

Cyber Espionage

Definition:

- Stealing sensitive information for political, military, or economic purposes.

Snake Malware

- Russian FSB cyber espionage tool
- Developed around 2003
- Stole sensitive information
- Affected Windows, Linux, and macOS
- Used against NATO(North Atlantic Treaty Organization), governments, research organisations, financial institutions, etc.

Disinformation

Definition:

- False or misleading information spread intentionally.

Examples:

- Election manipulation
- Deepfakes
- Panic buying caused by misinformation

Scams

Examples:

- SMS scams
- Phone call scams
- Investment scams

Important statistic:

- Australians lost over \$2 billion to scams in 2024.

Different Hats

- **Black Hat Hacker = Cracker / Criminals | Engages in illegal activities for personal gains**
- **White Hat Hacker = "Ethical" Hackers | Stays within the limit of the laws to fight cybercrime**
- **Grey Hat Hacker = Somewhere in between | Engages in illegal activities, but not with malicious intent**

Week 2 Human Factors

- Humans can have positive and negative impact on cybersecurity
- Human often cause cyber incidents by being careless
- Most dominant attack vector is caused by malware or ransomware
- Malware often comes from a social engineering attack, which humans are vulnerable to

Social Engineering Attack

- Gain illegal access to victim's device
- Induce(引导) the victim to divulge(泄露) sensitive information

Tactics

- Exploit several vulnerabilities in humans
 - Compassion
 - Curiosity
 - Greed....
 - Different forms
 - Emails
 - Social Media
 - Job Posting Sites
 - In Person.....
-

Insider Threat

- Security threat originating from within the organisation
 - Malicious insider (intentionally steals data)
 - Negligent insider (careless mistakes)
 - Compromised insider (account taken over by attacker)

Phishing

- Comes through many forms
 - Email
 - Fraudulent Websites
 - Malware
 - Man in the Middle Attacks
 - XSS Attacks
- **Spear Phishing**
 - A targeted phishing attack aimed at a specific individual or organisation
 - More personalised than normal phishing
 - Often uses information gathered from social media or OSINT

Counter Measures

- Non-Technical
 - Cyber Awareness Training
 - Wargaming
 - Practising cyber incident scenarios before they happen
 - Promoting Cyber Safety
 - Use of Policies
- Technical
 - Email Filters
 - Multi-Factor Authentication
 - Digital Signatures
 - Access Management

- Difference between Cyber Wargaming and Ethical hacking
 - Cyber Wargaming
 - A simulated cyber incident exercise used to train people and test an organisation's decision-making, communication, policies, and incident response.
 - It is mainly a non-technical countermeasure
 - Ethical hacking is an authorised simulated cyberattack
 - It is usually a part of penetration testing
 - A tester actively looks for and may exploit vulnerabilities to evaluate security

Cyber Vetting

- Cyber Vetting is a background check activity based on the candidate's online footprint

Cyber Criminal Psychology

- Criminal profiles are established bodies of knowledge that help law enforcement prevent crime.
 - Study Criminals commit crimes, go to jail....
 - Cyber Criminals are not easy to be caught,

Data-Driven staffing

- Cybersecurity teams, especially the Security Operation Center, often deal with many alerts and incidents.
- If there are not enough staff, people become overloaded

Solution: Data-Driven staffing

- Use evidence such as alert volume, incident numbers, severity, response time, and staff workload to decide how many cybersecurity staff are needed
- Help avoid burnout because staff are not overloaded beyond what they can realistically handle

- Cybersecurity work can be stressful, especially for SOC analysts and incident responders. If staff are burned out, they may miss alerts, make poor decisions, respond slowly, or be ineffective during incidents.
- Example
 - If a SOC receives 900 alerts per day, and one analyst can properly investigate 100 alerts per shift, then having only three analysts is not enough. They can only handle 300 alerts. So many alerts maybe ignored or rushed. This can cause burnout and missed attackers
 - Hire more analysts, reduce unnecessary alerts, automate low-risk alerts, rotate shifts, outsource monitoring through MDR (Managed Detection and Response)

Week 3 Cryptography

Terminology

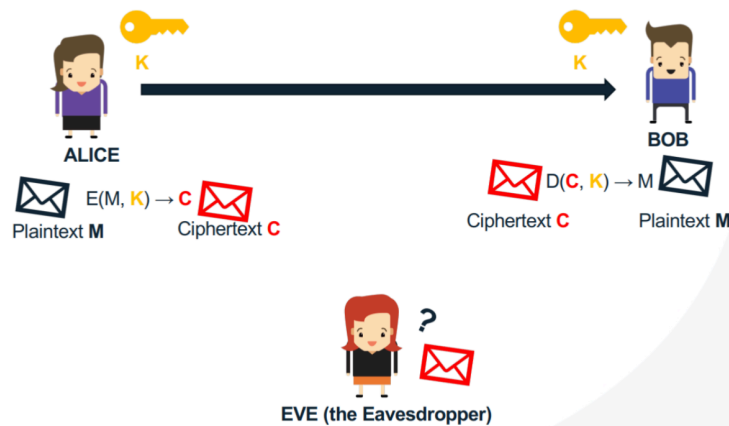
- Cryptography - More practical (engineering) development and study of encryption systems
- Cryptology - More academic (mathematical) study of encryption and their properties
- Cryptanalysis - Analysing and breaking cryptographic systems

Goals of Cryptography

- **Confidentiality:** Only authorised people get to see the data
- **Integrity:** There is certain assurance that data has not been manipulated or corrupted
- **Authenticity:** There is certain assurance we know sent / created the data
- **Non-Repudiation:** Certain assurance that author / sender cannot deny an action

Symmetric Key Encryption

Symmetric Key Encryption



- Using the same key to encrypt and decrypt

Terminology

- **Plaintext:** original unencrypted message
- **Ciphertext:** encrypted message
- **Adversary(对手):** The person/s you are trying to keep a secret from
- **Encryption:** The process of disguising sensitive information
- **Cipher:** The algorithm or process used to encrypt/decrypt
- **Key:** The secret cipher setting chosen known only to sender and receiver

Historic Symmetric Ciphers

CAESAR Cipher (shift cipher)

$E(M, n) \rightarrow$ shift each character by n ($1 \leq n \leq 25$)

$D(C, n) \rightarrow$ shift each character by ... $26-n$

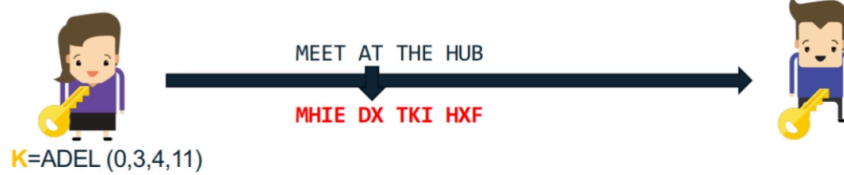
How to attack?

- Simple brute force

Vigenere Cipher

Vigenère cipher

ABCDEFGHIJKLMNOPQRSTUVWXYZ



$E(M, K) \rightarrow$ shift 1st char by K_1 , 2nd by K_2 , etc. ($1 \leq K_i \leq 25$)

$D(C, K) \rightarrow$ shift 1st char by $26-K_1$ etc



How to attack?

Frequency Analysis ☺

slide

$E(M, K) \rightarrow$ shift 1st char by K_1 , 2nd by K_2 , etc ($1 \leq K_i \leq 25$)

$D(C, K) \rightarrow$ shift 1st char by $26-K_1$ etc

- In this case the $K = \text{ADEL}$
 - $A = 0, D = 3, E = 4, L = 11$

Plaintext:	M	E	E	T	A	T	T	H	E	H	U	B
Key:	A	D	E	L	A	D	E	L	A	D	E	L
Shift:	0	3	4	11	0	3	4	11	0	3	4	11

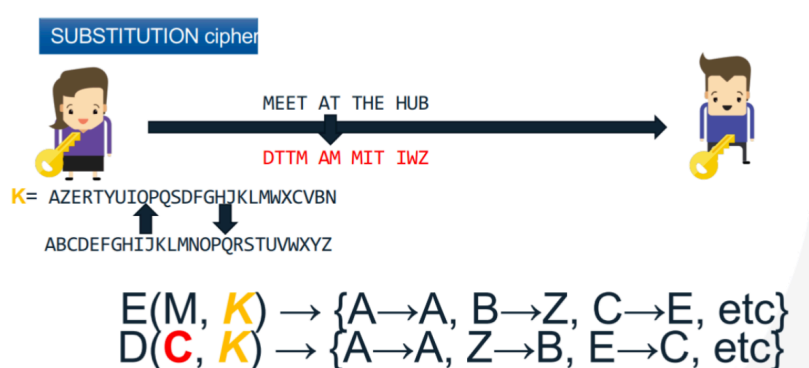
M + 0	=	M
E + 3	=	H
E + 4	=	I
T + 11	=	E
A + 0	=	A
T + 3	=	W
T + 4	=	X
H + 11	=	S
E + 0	=	E
H + 3	=	K
U + 4	=	Y
B + 11	=	M

How to attack?

- Frequency Analysis

Substitution Cipher

Historic Symmetric Ciphers



How to attack?
Frequency Analysis ☺



How to attack?

- Frequency Analysis

Kerckhoffs's principle

1. Encryption scheme should be open (don't rely on security by obscurity)
2. Only the secret key should be kept secret
3. It should be easy to change keys (in case of a compromise)

XOR

- XOR can encrypt data by combining the message with a key, and the same key can decrypt it because XOR reverses itself

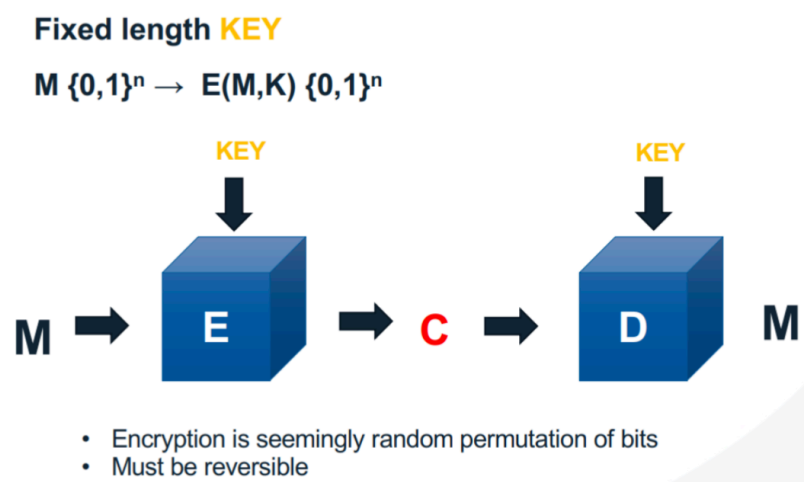
One-Time Pad

- Mathematically proven perfect secure
 - key must be completely random

- key must be as long as the plaintext (long key)
- can only be used once
- This is not practical

Block Cipher

Block Ciphers



$M \in \{0,1\}^n$ # Meaning the message is a binary string of length n
 $E(M, K) \in \{0,1\}^n$ So the encryption output is also length n

- Encrypt data in blocks of predetermined size
 - Takes a fixed-size message block, uses a secret key to scramble it into ciphertext, and then use the same key to reverse the process and recover the original message
- Different modes of operation
 - **Electronic Code Book (ECB)**
 - Bad
 - Same plaintext block $\rightarrow$ same ciphertext block

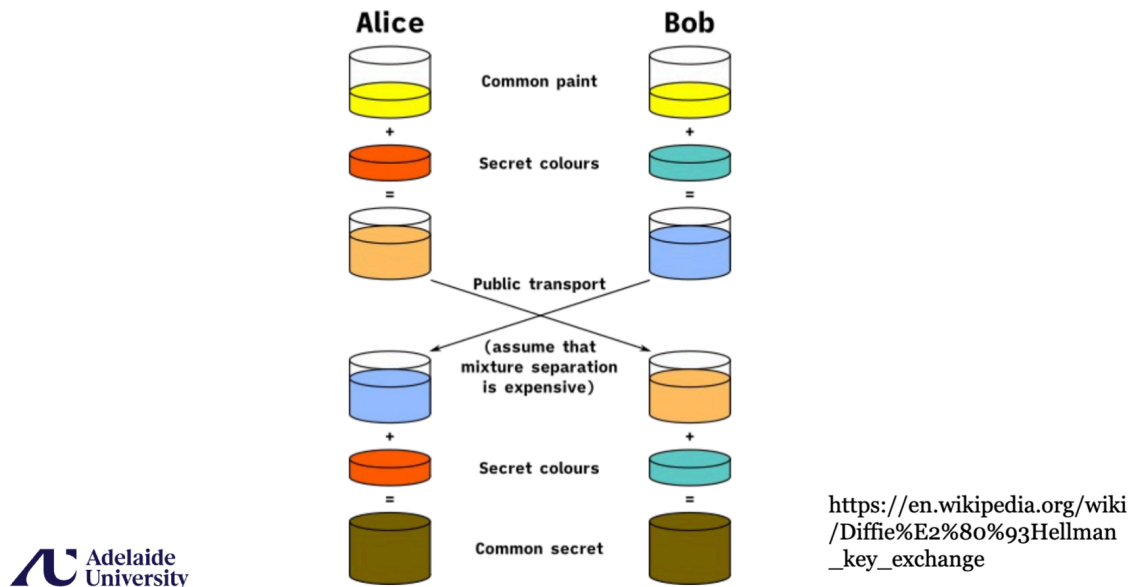
- Patterns can remain visible
- Not recommended for secure applications
- **Cipher Block Chaining (CBC)**
 - CBC does not encrypt each block independently
 - Before encrypting a block, CBC combines it with the previous ciphertext block
 - The first block has no previous ciphertext block, so it uses an IV(initialisation vector) instead
 - Which creates a chain
- **Counter Mode (CTR) - NIST recommended mode**
- **Block ciphers are usually stronger as each output block is produced through many rounds of mixing, substitution, permutation and key operations.**
 - Even a tiny change in the plaintext or key can create a very different ciphertext. Which makes it harder to attackers to find patterns
- Common Ciphers
 - DES - no longer secure
 - 3DES
 - AES

Stream cipher

- Encrypts data one bit at a time
- Faster and less resources than block ciphers
 - Stream ciphers often just generate a key stream and use XOR, which is simple operation for computers
- **Not as strong as block ciphers**
- RC4 - Used in wireless networks
- A5 - Used in mobile networks

Diffie-Hellman Key Exchange (DH)

Diffie-Hellman Key Exchange (DH)



- This is not a symmetric encryption algorithm as it does not directly encrypt messages
- It helps create/exchange the secret key, then that key can be used with symmetric encryption like AES
- Yellow paint = public information
- Alice's orange paint = Alice's Private secret
- Bob's blue paint = Bob's private secret
- Alice mixes yellow + orange and Bob mixes yellow + blue
 - Then they send these mixed colours to each other publicly
- Alice adds her secret orange to Bob's mixture
- Bob adds his secret blue to Alice's mixture
- Both end up with the final colour
- Then the final colour means the shared secret key
- So the attacker can see the public colours, but cannot easily separate the mixed paint to find the private secret colours.
 - Alice and Bob create the same secret key but never send the secret key directly

Symmetric Key Limitation

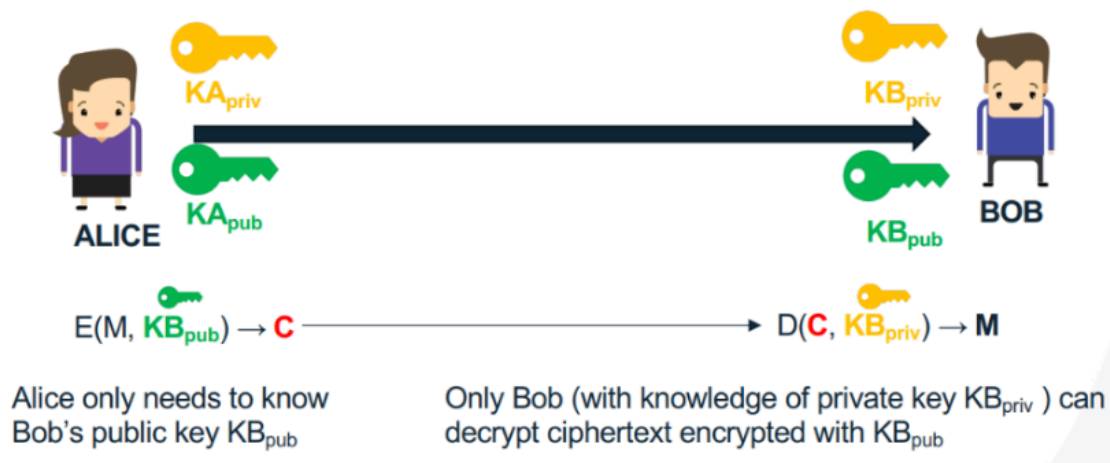
- How can we safely share the secret key?
- Too many people means there will be too many keys
 - Take a lot space and hard to manage

Asymmetric Key Encryption

- Key for encryption is different from key for decryption

Public Key Cryptography (RSA)

- Each person has two keys



- Alice encrypts the message using Bob's public key
 - Message + Bob's public key = Ciphertext
- Then Bob decrypts it using his private key
 - Ciphertext + Bob's private key = Original message

RSA

- Neither Block cipher nor stream cipher
- A public key encryption method. Its security is based on the difficulty of factorising very large numbers
 - Choose two very large prime numbers
 - p and q

- Multiply them together
 - $n = p \times q$
- Multiplying p and q is easy, but finding p and q from n is very hard when the numbers are huge
 - Easy: $p \times q = n$
 - Hard: $n \rightarrow p$ and q
- The public key is based on n
 - **$K_{pub} = f(n)$**
 - Anyone can know the public key and use it to encrypt messages
- The private key requires knowing p and q
 - **$K_{priv} = g(p, q)$**
- **Trapdoor function** = The RSA factorisation idea: easy to multiply p and q , hard to reverse unless knowing the secret **p and q / private key**

RSA Limitation

- RSA is computationally expensive
 - Much slower than symmetric encryption such as AES
 - Usually only used to exchange a session key
 - Actual data is encrypted using AES or another symmetric cipher
- RSA is not used to encrypt long long messages directly
 - RSA plaintext must be smaller than the RSA key modulus
 - Padding reduces the maximum message size
 - For a 512-bit RSA key, the block size is 64 bytes
 - With PKCS#1 padding, 11 bytes are used for padding, so max plaintext could be accepted is 53 bytes
 - If the message is too long, OpenSSL shows "data too large for key size"
 - RSA is usually used to encrypt a temporary AES/session key, while AES encrypts the actual long message

RSA used as Digital Signature



- Sender use their own private key to prove the message came from them
- Alice sign a message M with her private key $\rightarrow S$
 - S is the digital signature
- Bob use Alice's public key to check if the message is actually from Alice

Encryption

- Provides confidentiality
- Prevents unauthorised users from reading data

Digital Signature

- Provides authenticity
- Provides non-repudiation
- Confirms who sent the message

Cryptographic Hash

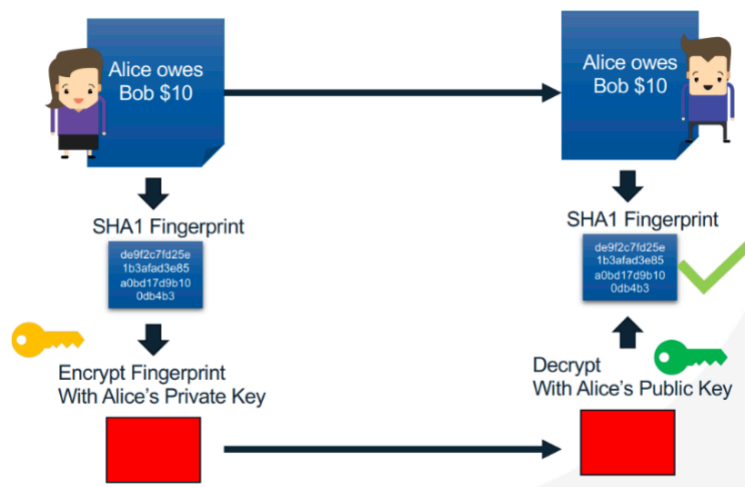
- Digital fingerprint of data
- Put a message/file into a hash function

Message M $\rightarrow$ SHA-1 $\rightarrow$ Message Digest

- The output is called a hash value, digest, or message digest
- One-way function

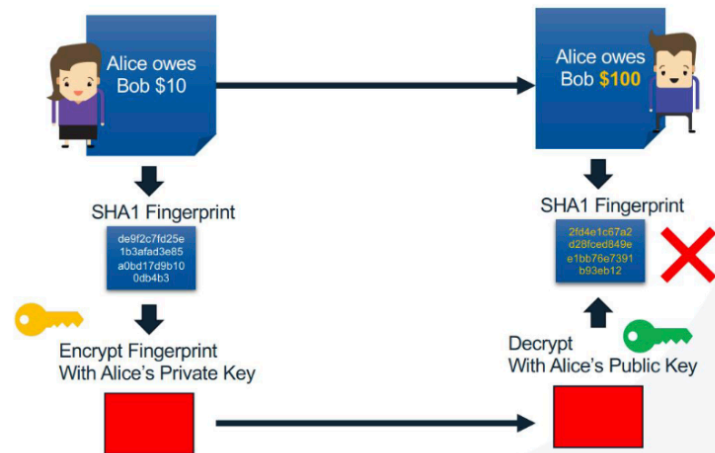
- Message → Hash
- Hash is not an encryption, cannot decrypt a hash
- Collision resistant
 - No two different messages would produce the same hash
- Variable input, fixed output
 - the input can be any size
 - but the output size is fixed
- The hash provides integrity assurance of M
 - Even a single bit changes in M, the resulting Message Digest would be completely different

Document Signing



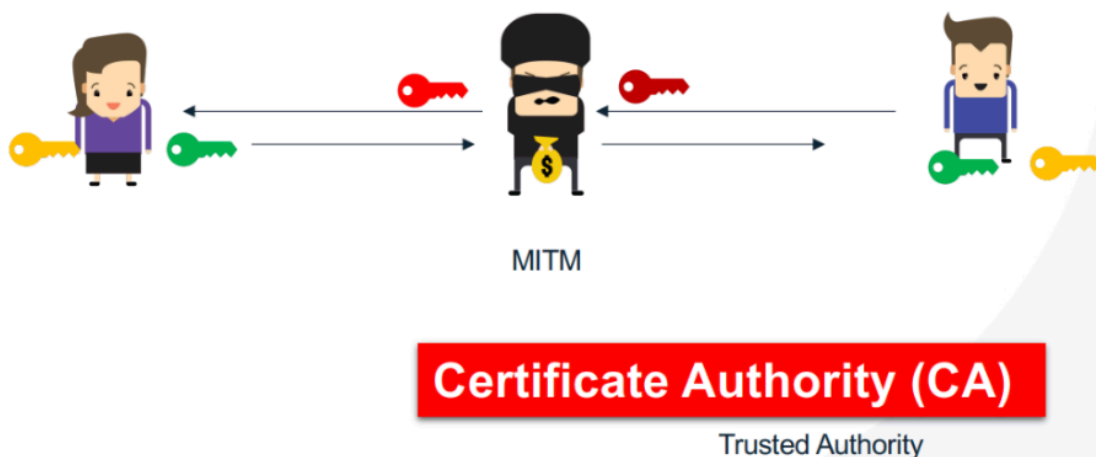
1. Hash the document
 - Document → SHA-1 fingerprint
2. Sign the fingerprint
 - Alice encrypts the fingerprint using her private key
 - Fingerprint + Alice's private key = Digital signature
3. Send document + signature
4. Bob verifies it

- Bob uses Alice's public key to decrypt the signature and recover the fingerprint
- Then Bob also hashes the document and compare the fingerprint



5. Document signing means Alices hashes the document, signs the hash with her private key, and Bob checks it using Alice's public key.
6. If the hash does not match, then the message is modified.

Man in the middle (MITM)



- Bob wants Alice public key
- Attacker in the middle can intercept the communication and say
 - "Here is Alice's public key"
 - Then attacker sends his own public key

- Then Bob encrypts messages using the attacker's key, thinking it is Alice's key
 - Then attacker can
 - Read Bob's message
 - Re-encrypt it
 - Send it to Alice
- Bob and Alice may not even know there is someone in the middle
- Certificate Authority
 - A trusted organisation that confirms the public key
 - It gives Alice a digital certificate
- Bob does not just trust a random public key but trust the public key that CA has verified

HTTPS/TLS

1. Browser wants a secure HTTPS connection
2. Server replies with its certificate
3. Browser checks the certificate
 - Browser checks with a trusted Certificate Authority (CA)
 - The certificate contains the server's public key
- Browser checks the certificate
 - Check with a trusted Certificate Authority (CA)
- Browser creates a session key
 - Browser creates a temporary symmetric key called a session key
 - Then it encrypts this session key using the server's public key
 - Only server can decrypt it because only the server has the matching private key
- Both sides now share the session key
- Use session key as public key is slower

- Symmetric encryption with a session key is much faster, so it is better for sending lots of web data

Key Length

- Longer the key, harder to break
- 4-bit key only has

$$2^4 = 16 \text{ possible keys}$$

- 256-bit key

$$2^{256} \text{ possible keys}$$

- The number will be extremely huge, hence the brute force will not be realistic

Storage of Passwords

- Storing and sending plaintext password is wrong
- Encryption is also wrong
 - if key is stolen, all passwords are exposed
 - Same password will have the same ciphertext
 - Ciphertext length - password length

Solution: Hashing

- Same length output
- No key management required
- Same password still have the same ciphertext - Precomputation attack still feasible
 - Salt
 - Random value added to the password before hashing
 - So that even the same password, their stored hashes will become different

- Salt does not need to be secret, it can be stored in the database with the user
- Salt is randomly generated for each user
- Salt does not make one password harder to guess if attacker is attacking only on one user
 - But salt make precomputed rainbow tables much less useful as attackers would need to separate the table for every possible salt
- Rainbow table
 - A precomputed table used to crack password hashes faster

Plain password	Hash
password123	hash value
qwerty	hash value
admin123	hash value

Password Attack Tools

- Offline Password Cracking
 - John the Ripper
 - Hashcat
- Online Password Cracking
 - THC Hydra
 - Brutus
 - Other
 - Cewl - dictionary-builder

Week4 Security Assessment

CIA

- Confidentiality
 - Controlling access to data/system

- Integrity
 - Preventing tampering with data/systems
- Availability
 - Ensuring access to data/system

Breach C.I.A

- Malware
- SQL injection / Cross-Site Scripting
- Remote Access Execution (RCE)
 - Buffer overflow, file upload
- Exploit weak configuration
 - Password = Password
 - Admin = Admin

C.I.A Protection Strategy

- Firewall and Intrusion Protection (IPS)
- Antimalware
- Design secure systems
- Access control
- Configuration hardening
- Patching and upgrades
- Intrusion Detection (IDS)
- SIEM (security information and event management)
- User / Entity behaviour analytics
- Incident Response

What is Vulnerability?

- A weakness in software, hardware or an organisation process that can be exploited by an attacker
- Compromise the C.I.A of a system or its data.

Security Assessment

- Testing/evaluation of administrative, physical and technical controls to determine
 - Implemented correctly
 - Operating as intended
 - Producing the right outcome
- Produces a prioritised list of actions to improve the security of the organisation
- Performed periodically

Types of Assessments

- Vulnerability Scanning
- Configuration Review
- Penetration Testing
- Red Teaming
- Code Review
- Architecture Review

Security Assessments Classification

Black Box

- No knowledge of application
- Focus on exposed weakness
- Cost effective
- Simulated real attack
- Can miss weaknesses

White Box

- Full knowledge of architecture and access to code

- More comprehensive and complete
- Can be time consuming

Automated

- Fast
- Cheap
- Not always accurate
- No context

Manual

- Interactive
- Slow
- Expensive
- More accurate
- Understands context

Dynamic

- Code is executed
- Interactive with other components (database, middleware)
- No need to have source code
- Black Box

Static

- Code is not executed
- Binary static
- Source code static (same as code review)
- Bytecode static
- White box

Application-Specific

- Scope is limited to a single application or infrastructure

- No social engineering
- Less expensive
- Focused on fixing weakness in software

Open-ended

- Whole organisation
- Include social engineering
- Include physical intrusion
- Simulates realistic attack
- Combine with blue teaming
- More time-consuming and expensive
- Focused on testing holistic (整体的) defence including detection and response

Ethical Hacking Model (PTES = Penetration Testing Execution Standard)

1. Pre-Engagement

- what systems can be tested
 - what systems are out of scope
 - testing dates and times
 - allowed methods and tools
 - legal permission
 - communication rules
 - emergency stop rules

2. Intelligence Gathering / Reconnaissance / OSINT

- Collect information about the target before attacking
 - company domains and subdomains
 - public IP ranges

- employee names and emails
- technologies used by the website
- DNS records
- information from Google, Shodan, Censys, Whois, social media, job ads

3. Threat Modeling

- Use the collected information to decide likely attack paths and valuable targets.
 - what assets are important
 - what attackers would target first
 - what attack paths are possible
 - which systems are more exposed
 - which weaknesses may cause the most damage

4. Vulnerability Exploration

- Test whether discovered vulnerabilities can actually be exploited
 - port scanning
 - service/version detection
 - checking known vulnerabilities
 - vulnerability scanning
 - configuration review
 - web application testing

5. Exploitation

- The Tester tries to prove whether the weakness can really be bad
 - exploiting SQL injection
 - exploiting weak passwords
 - using Metasploit
 - bypassing authentication
 - gaining shell/access

6. Post-exploitation

- After gaining access, the tester checks what an attacker could do next
 - privilege escalation
 - accessing sensitive data
 - moving to other systems
 - pivoting through the network
 - checking how much control the attacker could gain

7. Reporting

- Explain findings, risk level, evidence, impact, and recommendations
 - what was found
 - evidence/screenshots
 - risk rating
 - business impact
 - how it was exploited
 - recommended fixes
 - priority of remediation

Penetration Testing Frameworks

- Penetration Testing Execution Standard (PTES)
- Open Source Security Testing Methodology (OSSTM)
- OWASP Testing Guide
- PCI (Payment Card Industry) Penetration Testing Guideline

Penetration Testing Phases

1. Planning

- Agree on what can be tested, what cannot be tested, when test happens, what tools are allowed, and how communication or report works
- Understanding and agreeing to:

- Scope and Goals
- Constraints
- Timeframe
- Communication procedures
- Methodologies and tools
- Sign engagement letter

2. Reconnaissance - information gathering phase

- Try to learn about the target without attacking directly
- OSINT (Open Source Intelligence)
- Google dorking
- Whois / DNS lookup
- Social Media
- Shodan / Censys
- Company websites and job posts

3. Enumeration and Vulnerability Analysis

- Which hosts are alive, what ports are open, what services are running, what versions are exposed, and whether known vulnerabilities exist
- Example
 - Ping sweep: find live machines
 - Port scanning: find open ports like 80, 443, 22
 - Banner grabbing: find software version
 - Nessus/OpenVas: find known vulnerabilities

4. Exploitation

- Tester tries to prove the vulnerability is real by exploiting it
 - Automated exploitation
 - Metasploit
 - SQLMap

- Exploit DB
- POC codes
- Manual exploitation
 - Social engineering / physical

5. Reporting

- What was found, how serious it is, what evidence proves it, what impact it could have, and how to fix it.
- Rating Risks based on impact and ease of attack
- Remediation recommendations
- Context is important
- What data is leaked? Is it sensitive?
- Do you need to be inside the network?
- Do you need to have authenticated

Vulnerabilities Include

- Misconfiguration
 - Default and weak passwords
 - Weak Protocols
 - ...
- Software Bug
 - Buffer overflow
 - Input validation failures
 - Authorisation breakdown
 - ...

Vulnerability Scanning

- Non-credentialed scanning
 - Scanner does not log in to the system

- eg. The scanner checks a server from the internet and sees port 80, port 443, and port 22 are open
- Hence it can only see things that are publicly exposed
- Quick
- False positives based on banner information
- Can be destructive or nondestructive
- Credentialed scanning
 - Scanner has a valid login account, often with privileged access
 - Require privileged user account
 - Verifies internal configurations
 - Check software versions
 - Less false positives
 - More comprehensive

Scanning tool

- Tenable Nessus
- Rapid7 Nexpose
- OpenVAS
- QualysGuard

Automated Vulnerability Assessment (VA)

- Scans networks or web applications
 - Scan a company network, website, server, web app
- Looks for known vulnerabilities
 - Check against known problems, like old software versions or known CVEs
- It is good for a broad initial sweep
 - Useful at the start because it can quickly check many systems
- Not perfect

- The tool can make mistakes
 - False positive (automated tools don't verify, only based on returned info)
 - False negative (automated tools miss stuff)
- Examples of tools
 - Nessus
 - OpenVAS
 - Acunetix

Penetration Testing vs Vulnerability Assessment

PT - find, exploit, and prove impact

- Identifies AND exploits vulnerabilities
- Often chain vulnerabilities
- Often use pivot to maximise reach
 - Meaning: Use one compromised system to reach other systems that were not directly accessible before

VA - find and list weaknesses

- Identifies but do not exploit vulnerabilities
- Hypothesise chained attacks
- Risk assessment based on likelihood and impact
- More focus on configuration and patching

Cataloguing Vulnerabilities

CVE = Common Vulnerabilities and Exposures

- ID/Name of the vulnerability
- List of publicly disclosed security flaws
- Used to uniquely identify vulnerability and to coordinate efforts

Example:

- CVE-2021-44228
 - This is the CVE ID for Log4Shell
- One official name/number

NVD = National Vulnerability Database

- NVD gives more detailed information about the CVE
 - vulnerability description
 - affected software
 - CVSS score
 - severity
 - links to analysis
 - related CWE
 - whether it is known exploited, KEV (Known Exploited Vulnerabilities)

CVSS = Common Vulnerability Scoring System

- Gives a score from 0 to 10 to describe the technical severity of a vulnerability
- CVSS:3.0/AV:L/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L
 - ☐ Version
 - ☐ AV: Attack Vector (Physical, Adjacent, Local, Network)
 - ☐ AC: Attack Complexity (Low, High)
 - ☐ PR: Privilege Required (N/Y)
 - ☐ UI: User Interaction (N/Y)
 - ☐ S: Scope (Unchanged/Changed)
 - ☐ C: Confidentiality
 - ☐ I: Integrity
 - ☐ A: Availability
- How CVSS score is calculated at a basic level
 - **Exploitability metrics**
 - How difficult is the compromise
 - (AV, AC, PR, UI)
 - **Impact metrics**

- Direct consequences of compromise
- (C,I,A),S
- CVSS does not measure how widespread the vulnerability is
 - A vulnerability can affect billions of devices but still have a medium CVSS score if it is hard to exploit or has limited technical impact

CWE = Common Weakness Enumeration

- The general weakness category
 - A system for categorising software weaknesses and vulnerabilities
- Example
 - CWE-20: Improper Input Validation
 - CWE-200: Information Exposure

KEV

- Known Exploited Vulnerabilities
- Maintained by the Cybersecurity & Infrastructure Security Agency (CISA)
- Used by organisations to prioritise vulnerabilities

Summary of the relationship

- NVD = database that contains CVE details, and may link that CVE to CWE and CVSS
- CVE identifies the specific vulnerability
- CWE describes the weakness category
- NVD stores details about the CVE, including CVSS score and related CWE

Different teams

Red team

- Attackers / offensive security
- Act like real attackers and try to break into the system

Blue Team

- Defenders / defensive security
- Monitor, detect, and respond to attacks
- Check SIEM alerts, investigate logs, block malicious IPs, respond to incidents
 - Protect the system and respond when attack happens

Purple Team

- Red team + blue team working together

Baseline Configuration Review

- Review-style assessment
- Are the system settings secure and following the best practice?
 - Are default passwords disabled?
 - Is unnecessary software/services turned off?
 - Are firewall rules secure?
 - Are admin privileges limited?
 - Are patches/settings following a security benchmark?
- Standards / tools
 - Microsoft Baseline Security Analyzer (MBSA)
 - CIS (Center for Internet Security) Benchmarks
 - ...

Code Review

- Check the source code to find security problems before attackers exploit them
- What it is checking
 - SQL injection risk
 - Command injection risk
 - Hardcoded passwords/API keys
 - insecure file upload

- weak input validation
- insecure authentication logic
- unsafe use of cryptography
- Different from normal code review (such as pair programming)
 - Normal code review check
 - Is the code clean? Is it readable? Does it work?
 - Security code review focuses on
 - Can this code be abused by an attacker
- Use of manual and automated tools to review security of source code
- **Automated tools**
 - Bandit (for Python)
 - Brakeman (for Ruby on Rails)
 - Veracode (various languages)
- Manual verification / review
 - A human checks whether the tool result is real and whether there are logic flaws the tool may miss

Software Testing Limitations

- Software testing can find problems, but it can never prove there are no problems
- No issues found does not mean issues do not exist

Third Party Assurance

- Instead of trusting what a company says about its own security, can use an independent third-party report to check whether their controls are reliable

Week 5 Threat Intelligence

Threat Data VS Threat Intelligence

- Threat data = raw facts / list of threats

- Example
 - This IP is suspicious, This malware hash exists
- Threat intelligence = data + context + meaning + action
- Example
 - The ransomware group targets restaurants using phishing, so the business should enable MFA, train staff, back up systems, and monitor suspicious logins

Why Threat Intelligence matters

- Help organisations get early warning about zero-day vulnerabilities
- Understand attacker motives
- Understand attacker TTPs
 - Tactics, Techniques, and Procedures
- Support executives in decision making

Threat Intelligence Users

- SOC people
- Analysts
- Architects
- Managers
- Executive Leaders : Public and Private

Threat Intelligence Types

Type	Meaning	Simple example
Strategic	High-level trends, for managers/executives	"State-based actors are targeting critical infrastructure."
Operational	Attacker behaviour and TTPs	"The attacker uses phishing, PowerShell, and privilege escalation."
Tactical	Technical indicators and specific details	Malware hashes, bad IPs, domains, ransomware names, IoCs

- Strategic: high level and focused on trends such as who are the state-based threat actors
- Operational: Focuses on TTPs
- Tactical: Highlights the types of Malware/Ransomware and IoCs

Threat Intelligence Contents

- Data aggregation (数据聚合) from multiple sources
- Data dissemination frameworks (数据发布框架)
- Automation and Triage(分诊)
- Insights on what to do

Category	Focused area	Example tools from slide
Threat Intelligence Platform / TIP	Collect, organise, enrich, and share threat intelligence from many sources	Recorded Future, ThreatConnect, Anomali, Mandiant, DeCYFIR
External Threat Intelligence / Threat Feeds	Provide information about current threats, attackers, malware, campaigns, bad IPs/domains	Kaspersky Threat Intelligence, Cisco Talos, McAfee Threat Intelligence, FireEye iSIGHT
Attack Surface / External Exposure Monitoring	Monitor what attackers can see from outside, such as exposed assets, leaked credentials, vulnerable systems	IntSights External Threat Intelligence, ZeroFox, CTM360
Brand / Digital Risk Protection	Detect phishing pages, fake social media accounts, impersonation, leaked brand data	ZeroFox, PhishLabs, Flashpoint, Echosec
Email / Phishing Threat Intelligence	Focus on phishing, malicious email, spoofed domains, email-based attacks	Mimecast Threat Intelligence, PhishLabs
Endpoint / Malware Intelligence	Detect malware behaviour, ransomware, suspicious files, endpoint attacks	CrowdStrike, Kaspersky, Mandiant, McAfee
Network / DNS Security Intelligence	Block malicious domains, command-and-control traffic, suspicious DNS activity	Cisco Umbrella, Cisco Talos, BloxOne Threat Defense

Category	Focused area	Example tools from slide
SIEM / Security Monitoring Integration	Collect logs and use threat intelligence to detect suspicious events	IBM, SolarWinds, AlienVault USM Anywhere
Incident Response / Investigation Support	Help investigate attacks, understand attacker behaviour, and respond to incidents	Mandiant, FireEye iSIGHT, CrowdStrike
Dark Web / Underground Monitoring	Monitor dark web, forums, leaked data, criminal marketplaces	Flashpoint, Echosec, DeCYFIR

What goes on a TI Report

- Evidence
- Facts
- Data
- Example

Two-Speed Approach to Security

Information Security Management - Slow

Step	Meaning
Identify and Plan	Identify assets, risks, threats, and decide what security should be done
Implement Controls	Put protections in place, such as MFA, firewall rules, policies, backups
Run	Operate the controls in daily business
Review / Audit	Check whether controls are working properly
Enhance	Improve the system based on audit results, new risks, or incidents

- This is slow because policies, audits, risk assessment, and control improvement take time
- It is about building a better security posture over weeks/months/years

SOC cycle - Fast

Step	Meaning
Assess	Know your assets, weaknesses, network, vulnerabilities
Intelligence	Learn about new threats, new IoCs, attacker methods, phishing campaigns
Threat Hunting	Actively search for hidden attacks
Detect	Use SIEM, IDS/IPS, alerts, antimalware, honeypots to find attacks
Respond	Block IPs, reset accounts, isolate infected machines, activate CIRT
Recover	Restore backups, rebuild systems, notify users, learn from the incident

- This is fast as attacks happen quickly, so SOC teams must monitor and respond quickly, often 24/7.

What is SOC

- SOC = Security Operation Center
- Organised security function/team that prepares for, monitors, detects, responds to and recovers from cyber incidents.
- Often running 24/7

SOC Cycle

Stage	Meaning	Example
Assess	Check your own environment before attack	Network scanning, asset enumeration, vulnerability scanning, config review, firewall review, pentesting
Intelligence	Gather outside threat information	New threats, phishing campaigns, new vulnerabilities, new IoCs
Threat Hunting	Actively search for hidden attackers	"What would we see in logs if someone is inside?"
Detect	Set up alerts and monitoring	SIEM alerts, IDS/IPS, antimalware, DNS sinkhole, honeypot
Respond	Limit damage during incident	Block IPs, reset accounts, isolate endpoints, activate CIRT

Stage	Meaning	Example
Recover	Return business to normal	Restore backups, re-image machines, notify users/authorities, learn lessons

Indicators of Compromise (IOC)

IOC = evidence/sign that malicious activity may have happened

- Examples
 - Unusual login times
 - High CPU/memory usage
 - unusual internet access from servers
 - registry changes
 - suspicious files
 - Office launching Powershell
 - Internal network scanning
 - Staff sending thousands of spam emails

What to know about MITRE ATT&CK

- A framework/matrix used to describe attacker TTPs
- Help defenders to understand how attackers operate, map attacks into stages, and design detection/response

SIEM / Splunk

SIEM = Security Information and Event Management

Simple meaning:

- A SIEM collects logs from many systems and lets analysts search, correlate, and alert on suspicious events
- Support the Detect and Threat Hunting parts in the SOC

Google	Splunk / SIEM
Searches web pages	Searches machine logs
You type keywords	Analyst types search queries

Google	Splunk / SIEM
Finds websites/content	Finds security events/log entries
Used by normal users	Used by SOC/security analysts

- Splunk is google for machine logs
- Splunk searches computer/security logs
- It works like a search engine for security evidence

Common Types of Cyber Threats

- Ransomware
- Malware
- Scams
- Systems and Network Attacks
- Business Email Compromise
- Data Breaches
- Identity Theft
- Hacking

Top Targets

- US, Ukraine, Israel, Japan, UK, Saudi Arabia, Brazil, India, Germany, Poland

Essential 8 Maturity Model

- Essential 8 = 8 basic cyber defence strategies, like patching, MFA, backups, restricting admin privileges
- Maturity Model = a level system used to judge how well the organisation has implemented those controls

Level	Meaning	Simple explanation
Level 0	Weakness in enterprise	The organisation has poor or incomplete security controls. Easy to attack.
Level 1	Publicly available exploits	Can defend against basic/common attacks using tools already available online.

Level	Meaning	Simple explanation
Level 2	Well-known tradecraft	Can defend against more organised attackers using known hacking techniques.
Level 3	Sophisticated threat actors	Stronger protection against advanced attackers, especially those exploiting old/legacy systems.

Essential 8 Mitigation Strategies

Strategy	Definition	Example
Patch applications	Keep software applications updated to fix known security vulnerabilities.	Update Chrome, Microsoft Office, Adobe Reader, or web applications when security patches are released.
Patch operating systems	Keep operating systems updated to fix security weaknesses.	Install Windows, Linux, macOS, Android, or iOS security updates.
Multi-factor authentication	Require more than just a password to log in.	User logs in with password + phone code, authenticator app, or security key.
Restrict administrative privileges	Limit admin rights so users only have the access they need.	Normal staff cannot install software or change system settings; only IT admins can.
Application control	Only allow approved/trusted applications to run.	Block unknown <code>.exe</code> files from running on company computers.
Restrict Microsoft Office macros	Block or limit Office macros because attackers often use them to run malware.	Disable macros in Word/Excel files downloaded from the internet.
User application hardening	Make user-facing applications safer by disabling risky features.	Disable Flash, Java in browsers, unnecessary browser plugins, or block ads/scripts from untrusted sources.
Regular backups	Keep copies of important data so systems can be restored after incidents.	Back up files daily and test recovery so ransomware cannot permanently destroy data.

Insider Threats

- A risk can be caused by someone inside the organisation

- Employee
- Contractor
- admin user
- former staff member
- trusted partner
- The harm could be intentionally or accidentally

Step	Meaning	Simple example
1. Definition	Decide what counts as an insider threat	Employee stealing data, careless staff clicking phishing links, admin abusing access
2. Detection & Identification	Find suspicious insider behaviour	Unusual login time, downloading many files, accessing data they do not need
3. Assessment	Judge how serious the risk is	Was it a mistake? Was data stolen? Is the person malicious?
4. Management	Take action to reduce the risk	Disable account, investigate, train staff, restrict access, report incident

International Practices for Threat Mitigation

- National Security Agency's Top 10

NSA Top Ten item	Simple meaning
Update and Upgrade Software Immediately	Patch apps and operating systems quickly so attackers cannot use known vulnerabilities.
Defend Privileges and Accounts	Protect admin accounts and user accounts from being stolen or abused.
Enforce Signed Software Execution Policies	Only allow trusted/signed software to run; block unknown or suspicious programs.
Exercise a System Recovery Plan	Practise restoring systems after attacks, especially ransomware.
Actively Manage Systems and Configurations	Keep devices, settings, firewall rules, and services properly controlled.
Continuously Hunt for Network Intrusions	Do threat hunting instead of waiting for alerts only.

NSA Top Ten item	Simple meaning
Leverage Modern Hardware Security Features	Use built-in security features in modern hardware, such as secure boot or hardware-based protections.
Segment Networks and Deploy Application-Aware Defenses	Divide the network into parts so one compromised machine cannot reach everything.
Integrate Threat Reputation Services	Use threat intelligence feeds to block known bad IPs, domains, URLs, and files.
Transition to Multi-Factor Authentication	Use MFA so stolen passwords alone are not enough to log in.

Ransomware Mitigation

Term	Full name	Focus	Simple meaning
EDR	Endpoint Detection and Response	Individual devices/endpoints	Monitors laptops, desktops, servers for suspicious activity
MDR	Managed Detection and Response	Outsourced security monitoring	A third-party security team monitors and responds for the organisation
XDR	Extended Detection and Response	Multiple data sources	Combines endpoint, network, email, cloud, identity logs for wider detection

Scams

- Indicators

Indicator	Meaning	Example
Generic greetings and signature	Message does not address you properly	"Dear customer" instead of your name
Spoofed hyperlinks and websites	Link looks real but goes to fake site	paypal1.com instead of paypal.com
Spelling and layout	Bad grammar, strange design, poor formatting	Bank email with weird spacing/logo

Indicator	Meaning	Example
Suspicious attachments & sender's address	Unexpected file or strange email address	support@microsoft-login.com sending a .zip file

- Common tricks = psychological pressure

Trick	Meaning	Example
Authority	Pretending to be someone powerful/trusted	"This is the police/bank/university."
Urgency	Making you rush	"Your account will close in 10 minutes."
Emotion	Using fear, love, sympathy, panic	"Hi mum, I lost my phone, send money."
Scarcity	Making it seem limited	"Only 1 hour left to claim prize."
Context	Using a situation that feels believable	Fake delivery message when you are expecting a package

Scam Mitigation

Point	Meaning	Simple example
Zero trust	Do not automatically trust messages, calls, links, or attachments	Even if a message says "bank", still verify it
Authentic source	Check information from the real source	Open the bank app/website yourself, not from the SMS link
Official instructions	Follow guidance from trusted organisations	Use bank/government scam advice, report scams properly
Scam gamification app	Use game-like training to teach people how to spot scams	Quiz app where users identify fake SMS/email examples

Week7 Network Security Fundamentals

What is Network Security

- Network security is any activity designed to protect the usability and integrity of your network and data

Sniffing and MITM

Sniffing

- Eavesdropping on network communications
- Sniffing affect CIA in Confidentiality
 - As attacker is reading information they should not see
 - usernames
 - passwords
 - emails
 - web traffic
 - files
 - cookies/session IDs

Packet sniffing methods

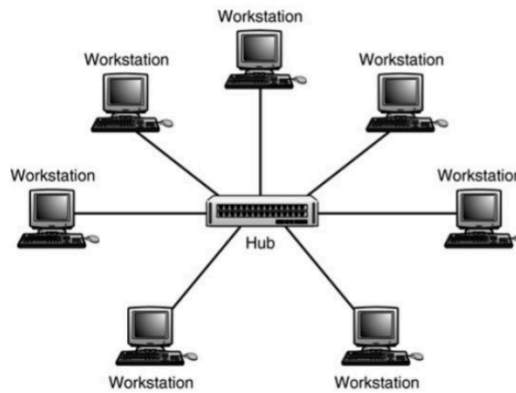
Method	Meaning
Non-switched network	Old/simple networks where traffic can be seen by many devices easily
Switched network via ARP cache poisoning	Attacker tricks devices into sending traffic through them
Physical tap device	A hardware device physically placed on the network cable to capture traffic
Open wireless network	Public/open WiFi where traffic can be easier to capture

Non-switched network

**Non-Switched
Network (free!)**



Layer-1 Hub



- A hub sends every packet to every connected computer
- If computer A sends data to computer B, the hub also forwards a copy to other workstation
- This means any computer on the same local network can "listen" to traffic that was not meant for it

Device	Behaviour
Hub	Sends traffic to all ports
Switch	Sends traffic mainly to the correct destination port

Open/Free Wifi

- Anyone nearby can join or listen to the wireless traffic

Problem	Meaning
No encryption / weak protection	Other people may capture traffic more easily
Anyone can join	Attackers can be on the same network as you
Fake hotspot risk	Attacker can create a WiFi name that looks legitimate
MITM risk	Attacker may intercept traffic between you and the internet
Sniffing risk	Attacker may observe unencrypted data

- Example:

Cafe_Free_WiFi

- The wifi may appear like this, but this maybe created by the attacker by using hotspot with that name
- When connect, attacker may try to
 - Capture your traffic
 - Redirect you to fake login pages
 - Steal session cookies
 - see websites you visit
 - trick you into entering your passwords

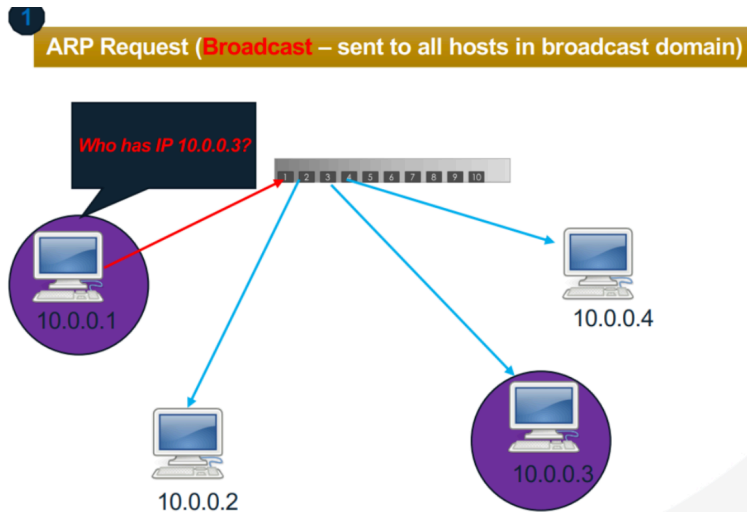
Physical Tap Device

- Physical ways to sniff traffic
- Attackers can sniff network traffic not only by software, but also by physical devices placed on the network
- Main idea
 - A physical tap device is hardware inserted into a network connection to copy traffic for monitoring or spying
 - Instead of using only Wireshark on a computer, the attacker/analyst uses a device to capture packets

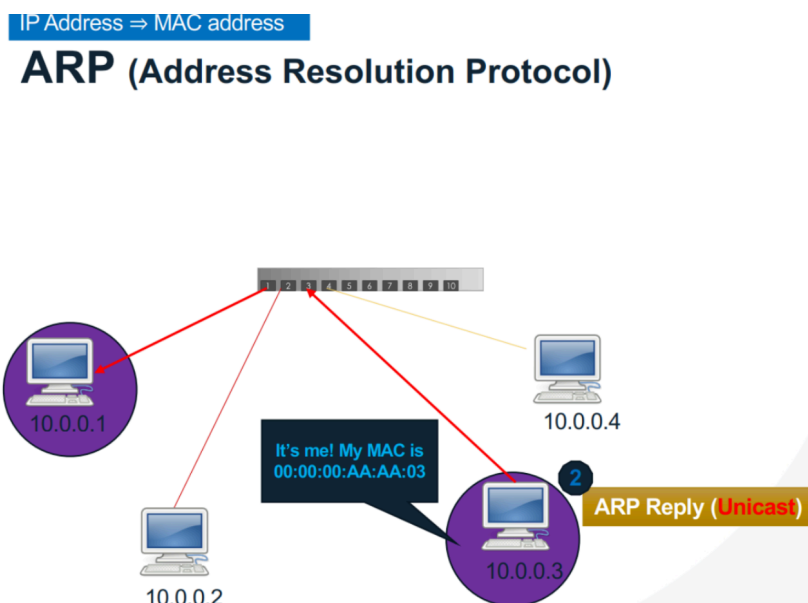
Example	Meaning
Hak5 LAN Turtle MITM	A small device plugged into a network to intercept/monitor traffic
TAP / SPAN / Mirror Port	A switch copies network traffic to a monitoring device
Optic Fibre Tap	A device captures signals from fibre optic cables
Cold War underwater cable tapping	Historical example of physically tapping communication cables

Switched network via ARP cache poisoning

ARP (Address Resolution Protocol)



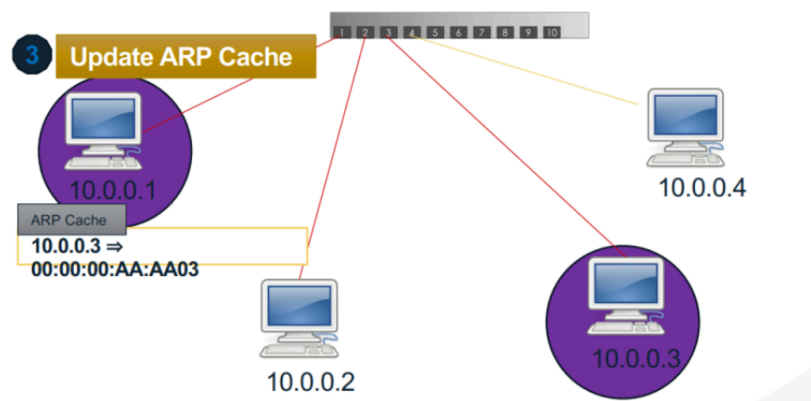
- Help a computer find the MAC address that belongs to an IP address inside the local network
- Computer 10.0.0.1 wants to talk to 10.0.0.3, but it only knows the IP address
 - 10.0.0.1 does not know the MAC address
- Then 10.0.0.1 sends an ARP request:
 - Ask Who has IP 10.0.0.3
 - This request is broadcast, meaning it is sent to everyone on the local network.



- Now the 10.0.0.3 replies

- "It's me, My MAC address is xxxxxx"
 - This is the ARP reply
 - It only sends the answer back to the original computer

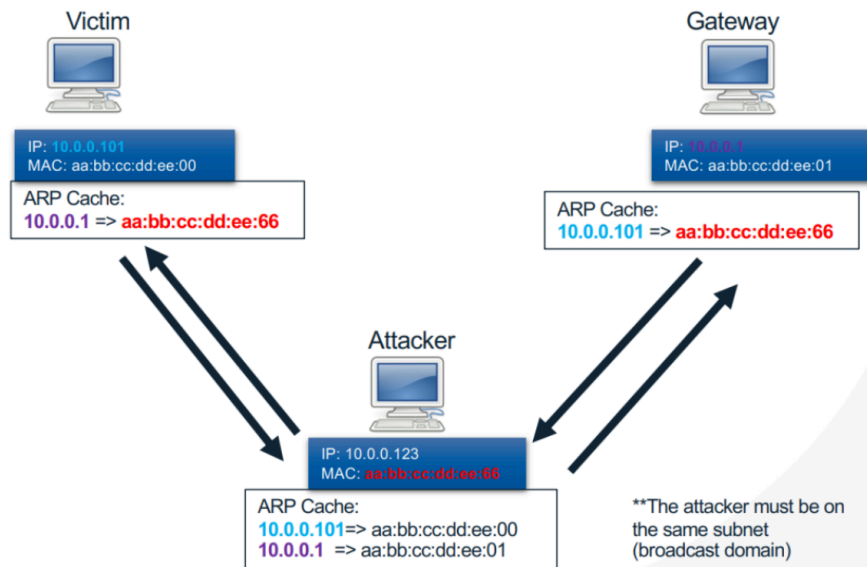
ARP (Address Resolution Protocol)



- After 10.0.0.3 replies with its MAC address, 10.0.0.1 saves the result locally
- A table called ARP is saved
 - 10.0.0.3 → 00:00:00:AA:AA:03

MITM using ARP Cache Poisoning

MITM using ARP Cache Poisoning



- ARP Cache Poisoning tricks devices into storing a fake IP → MAC address mapping
- The attacker must be on the same subnet / same broadcast domain
- The attacker tell the victim
 - Gateway IP 10.0.0.1 = attacker MAC aa:bb:cc:dd:ee:66
- **So the victim thinks the attacker is the gateway**
- The attacker tell the gateway
 - Victim IP 10.0.0.101 = attacker MAC aa:bb:cc:dd:ee:66
- **So the gateway thinks the attacker is the victim**
- **Result**
Victim → Attacker → Gateway
Gateway → Attacker → Victim
 - The attacker is able to sits in the middle and can sniff the traffic
- Why this works?
 - As ARP trusts replies too easily, if device accepts fake MAC mapping, then its ARP cache becomes poisoned.
- Attacker must be on the same subnet / same broadcast domain

DHCP

- When a device first joins a network, it does not automatically know how to communicate. It needs network settings.
- DHCP gives the device those settings automatically
- To connect properly, the device needs

Needed information	Meaning
IP address	The device's own address on the network
DNS server IP	Lets the device translate domain names into IP addresses
Gateway/router IP	Lets the device access outside networks/the internet

- Example: When a laptop joins WiFi, it needs to know:

My IP address = 192.168.1.20
DNS server = 8.8.8.8 or router DNS
Gateway = 192.168.1.1

- Without this, the laptop would not be able to know
 - What address it should use
 - how to find websites
 - how to reach the internet

DHCP Handshake

- DORA

Step	Name	Meaning
1	Discover	Client says: "I joined the network. Is there any DHCP server?"
2	Offer	DHCP server replies: "I can give you this IP, DNS, and gateway."
3	Request	Client says: "I choose this offer."
4	Acknowledgement	DHCP server confirms: "Okay, you can use this configuration."

DHCP Attacks and Defence

- Both ARP and DHCP have the same weakness
 - A device asks a question on the local network, and a fake attacker can answer first
- Two main attack ideas

Term	Meaning	Example
Spoofing	Attacker pretends to be a legitimate device/server	Fake DHCP server says "I can give you network settings"
Race condition	Whoever replies first gets trusted	Attacker replies before the real DHCP server

Example

- A new laptop joins the network and asks
 - Can any DHCP server give me network settings?
- The real DHCP server should reply
- But an attacker also replies quickly with fake settings
 - Something like this

```
Your IP: 10.0.0.50
Gateway: attacker's IP
DNS server: attacker's IP
```

- If the victim accepts the attacker's reply, the attacker can redirect or intercept traffic

Main vulnerabilities

- Broadcast protocols
 - DHCP requests are sent to everyone on the LAN
 - So the attacker can see the request and respond
- No trust anchor
 - There is no strong built-in way for the client to verify
 - "is this the legitimate DHCP server?"

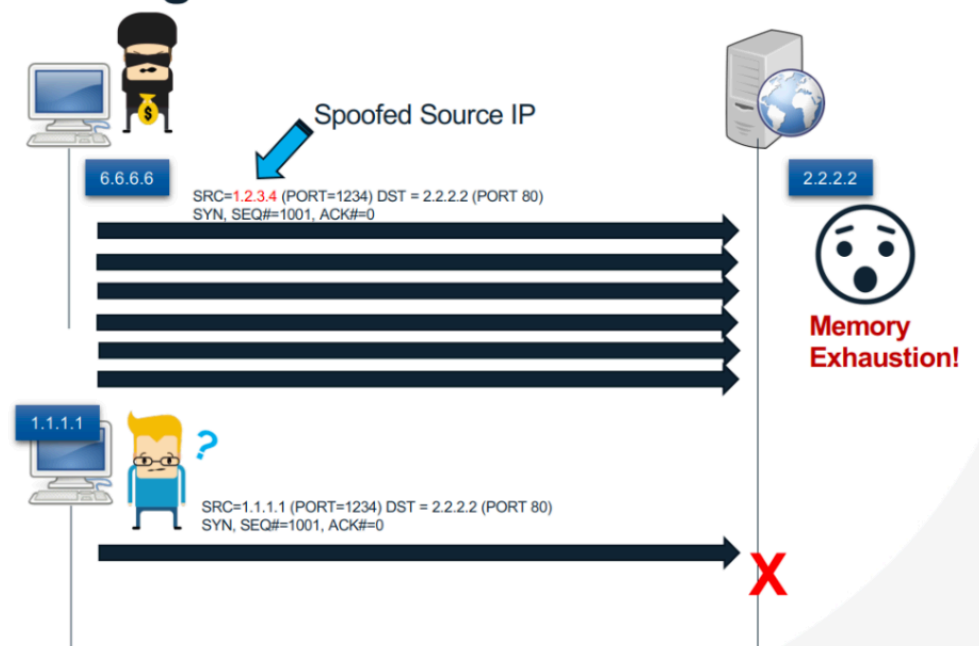
Sniffing and MITM Countermeasures

Countermeasure	Meaning
Encrypted communication	Even if attackers capture traffic, they cannot easily read it
SSL / SSH	Use secure protocols for web/remote access
Do not use FTP, Telnet, HTTP, SMTP	These can send data in plaintext, so attackers may read it
Avoid open wireless hotspots	Public/open WiFi makes sniffing and MITM easier
Dynamic ARP Inspection / DAI	Switch feature that checks ARP messages and blocks suspicious ARP poisoning
arpwatch	Tool that monitors ARP changes and alerts if something suspicious happens

DoS and DDoS attacks

- SYN Flooding DoS

SYN Flooding DoS



- SYN flooding attacks the TCP connection setup process by sending many connection request and not completing them

- In the image

Part	Meaning
Attacker 6.6.6.6	Sends many fake SYN requests
Spoofed source IP	Attacker pretends packets come from other IPs
Server 2.2.2.2	Receives too many half-open connection requests
Memory Exhaustion	Server resources are used up
Legitimate user 1.1.1.1 blocked	Real user cannot connect because the server is overloaded

Normal TCP connection

1. Client → Server: SYN
2. Server → Client: SYN-ACK
3. Client → Server: ACK

- In SYN flooding
 - Attackers sends many SYN packets to the server
 - Often use spoofed source IPs
 - Server replies with SYN-ACK and waits for the final ACK
 - The final ACK never comes
 - Server keeps many half-open connections
 - Server memory/resources become exhausted
- Then legitimate users may not be able to connect
- CIA impact
 - Mainly affects the availability, as the server becomes unavailable to real users

SYN Flood Countermeasure

- SYN cookies
- **When a server receives a SYN, it keeps memory/state for that half-open connection**

- But in a SYN flood, attackers send many SYNs and never finish the handshake, so the server's memory gets exhausted
- SYN cookies fix this by not saving the connection immediately
- Instead of opening a socket and storing connection state
 - Clients sends SYN
 - Server replies with SYN-ACK, but puts a special value called a cookie in the sequence number
 - Server does not store the connection yet
 - If the client is real, it replies with ACK containing the valid cookie
 - Server checks the cookie
 - If valid, the server opens the connection
 - SO the fake SYN requests do not waste as much server memory
- Example
 - Without SYN cookies

SYN received → server stores half-open connection → memory used

- With SYN cookies:

SYN received → server sends cookie → does not store connection yet

- Only after the final ACK proves the client is real

Valid ACK/cookie received → server opens connection

1. Client → Server
SYN
seq = 1000
2. Server → Client
SYN-ACK

```
seq = 7000    ← SYN cookie  
ack = 1001    ← client seq + 1
```

3. Client → Server

ACK

```
seq = 1001
```

```
ack = 7001    ← server seq + 1
```

4. Server checks:

```
received cookie = 7001 - 1 = 7000
```

Distributed Denial-of-Service (DDoS)

- DDoS = many systems attack one target at the same time
- As normal Dos may come from one machine
- A DDoS comes from many machines, so it is much harder to block
 - Attacker controls many compromised computers (botnet)
 - Attacker commands all of them to send traffic to the victim
- DDos is dangerous because

Reason	Meaning
Huge bandwidth	Many machines together can send much more traffic
Many sources	Traffic comes from many IP addresses, not just one
Hard to filter	Blocking one IP is not enough
Looks like normal traffic	Some DDoS traffic can look similar to real user traffic

Smurf attack

- Use ICMP ping requests and IP spoofing to flood the victim with replies
- The attacker does not direct send all traffic to the victim
 - He tricks many other computers into replying to the victim

How it actually happens

- Attacker sends an ICMP Echo Request - basically a ping

- Normal ping

- If A pings B

```
A → B: Are you there?  
B → A: Yes, I am here.
```

- So the reply always goes back to the source IP
- The attacker forges/spoofs the source IP address (lies about the source IP)
- The fake source IP is the victim's IP
 - The attacker sends a ping, but writes the victim's IP as the sender
- The ping is sent to a broadcast address
 - A broadcast address means: Send this message to everyone in this local network
 - So when the attacker sends a fake ping to the broadcast address, many computer would receive it
- Many computers on that broadcast network receive the ping
- They all reply to the victim
- The victim gets flooded with many ICMP replies
- Defence
 - Disallow broadcast ping

Amplified DoS

- Attacker uses another service as an "amplifier" to send much bigger traffic to the victim
- The attacker sends a small request, but the server sends back a large response to the victim.
- **How?**
 - There are three parties

```
Attacker = A  
Victim = V
```

DNS server = D

- The attacker wants to flood the victim, but instead of sending traffic directly, the attacker tricks the DNS server into doing it

- Normal DNS request

A → D: "Tell me the DNS information for example.com"

- Then the DNS server replies to the attacker

D → A: "Here is the DNS information"

- There is no victim involved

- In the attack, the attacker spoofs the source IP

- Attacker sends a packet to the DNS server, but writes the sender as the victim

A → D: "Tell me the DNS information for example.com"

- But inside the packet, it says

From: V
To: D

- So the DNS server thinks

- "The victim asked me this question. I should reply to the victim"

- Then the DNS server sends the response to the victim

D → V: "Here is the DNS information"

- The victim never asked for it, but it receives it anyway
- Why this becomes flooding
 - DNS response can be larger than the request
 - If attacker does thousands of times, using many DNS servers:


```
DNS server 1 → victim
DNS server 2 → victim
DNS server 3 → victim
DNS server 4 → victim
...
```

- Then the victim gets overloaded

DNS Attacks

DNS = Domain Name System

- Translate a human-readable website name into an IP address

```
google.com → 142.250.xxx.xxx
```

- Computer need IP addresses to connect
- Example: When user type www.google.com
 - The computer does not immediately know where that is
 - Then the computer will ask DNS server
 - "What IP address belongs to www.google.com?"
 - DNS replies with the IP address, then the computer can connect to the website

Term	Meaning
Domain name	Human-readable name, like <code>google.com</code>
IP address	Computer-readable address
DNS server / name server	Server that answers DNS questions
Recursive resolver	Server that does the DNS lookup for your computer
Stub resolver	The small DNS client on your computer that asks the resolver

Flow

Browser → Stub resolver: I need google.com
Stub resolver → Recursive resolver: What is google.com's IP?
Recursive resolver → DNS system: searches for answer
Recursive resolver → Stub resolver: Here is the IP
Stub resolver → Browser: Use this IP

Attacks

- Before computer asks DNS, it may check a local file called the host file
- The host file can manually say:

This domain name = this IP address

- If the attacker changes the hosts file, they can redirect a real domain to a malicious IP
- Example: /etc/hosts in UNIX or c:\windows\system32\drivers\etc\hosts in Windows)
 - "When i go to myuni.adelaide.edu.au, use IP address 43.241.200.112."
 - If that IP is controlled by an attacker, the user may be sent to a fake MyUni website

DNS poisoning (dnsspoof)

- Normal DNS process
 - Victim wants to visit

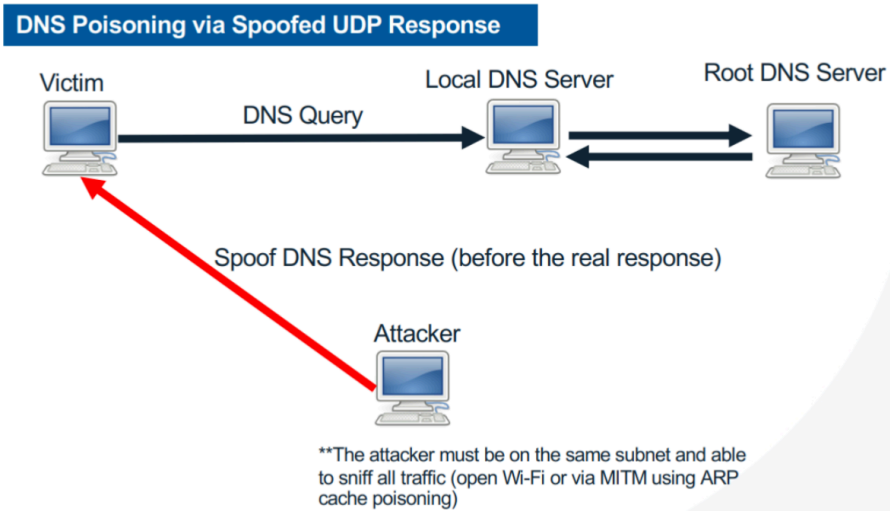
myuni.adelaide.edu.au

- Victim asks the DNS server

What is the IP address of myuni.adelaide.edu.au?

- The real DNS server should reply:

myuni.adelaide.edu.au = real IP address

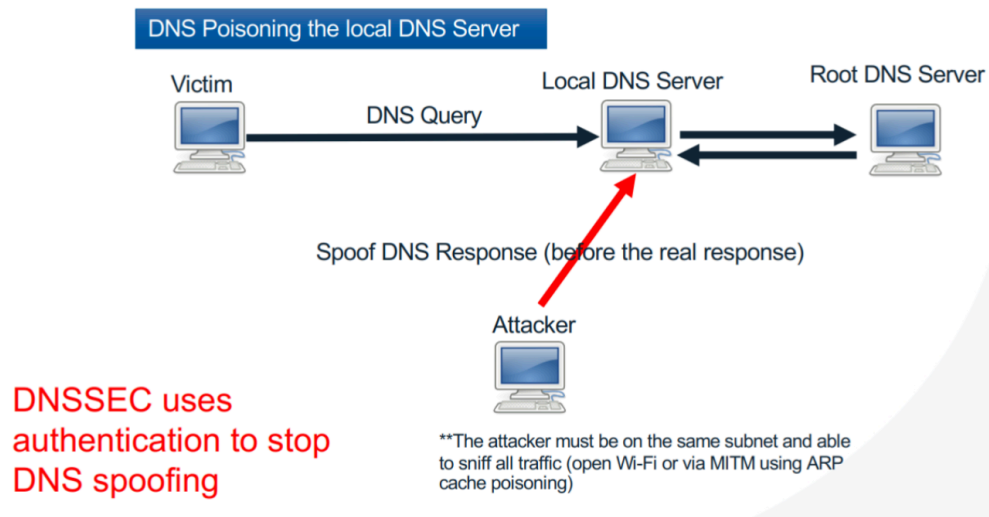


- If the attacker sees the victim's DNS query and quickly sends a fake answer

myuni.adelaide.edu.au = attacker's IP address

- If the attacker's fake response arrives before the real DNS response, the victim may accept it
- Then the victim goes to the attacker's fake website

DNS Poisoning



- Things could be worse
- If only the victim is poisoned (fake response send directly to the victim)
- If the local DNS server is poisoned
 - Many users using that DNS server may be affected

Solution: DNSSEC

- DNSSEC uses authentication to stop DNS spoofing
- DNSSEC check and authenticate DNS responses
 - So that the DNS server can verify whether the DNS answer is genuine or fake
- DNSSEC needs to solve two problems
 1. Is the DNS record correct?
 - Check Digital Signature
 - The real DNS name server signs the DNS record using its private key
 - Then others verify it using the server's public key
 2. Can we trust the name server?

- If a record has a signature, we still need to know
 - "if this public key really from the correct DNS server"
- Solution: Chain of trust
- DNSSEC uses a trust chain
- Starts from the root DNS server, then goes down the DNS hierarchy

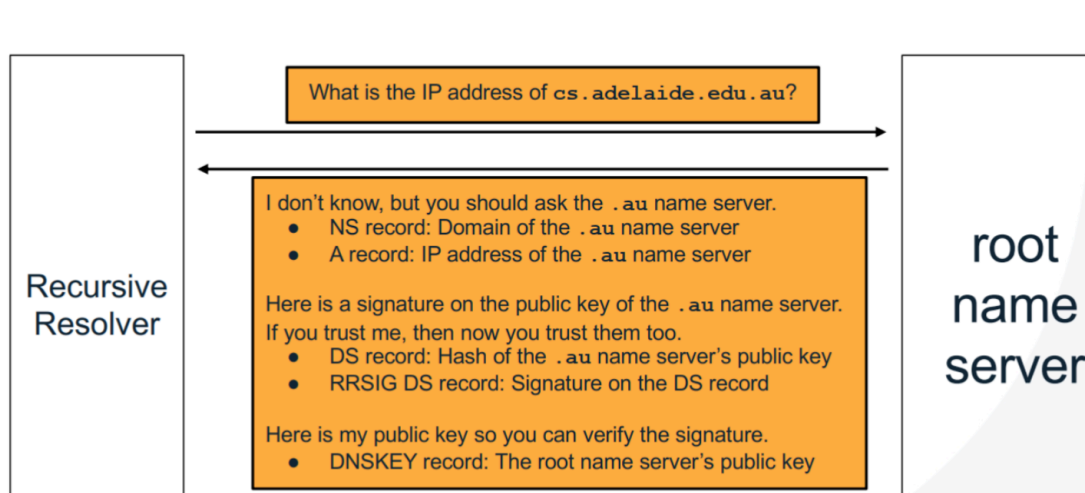
```

Root .
↓
.com / .org / .au
↓
example.com
↓
www.example.com

```

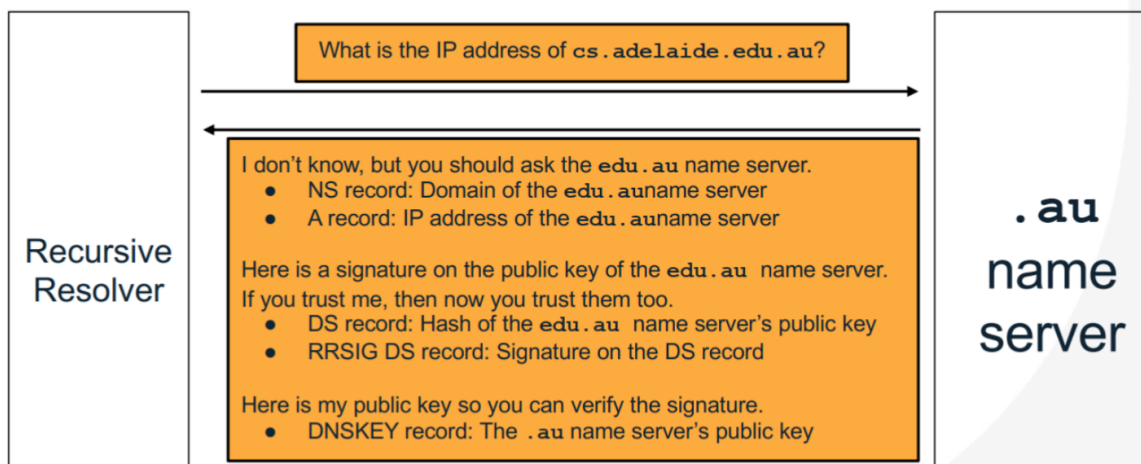
- Each level helps verify the next level
- So we trust the root, then the root help us trust .com, and then .com helps us trust google.com.....

Steps of a DNSSEC Lookup



1. Ask the root name server
- The recursive resolver asks:
 - What is the IP address of cs.adelaide.edu.au
 - Then the root name server says:

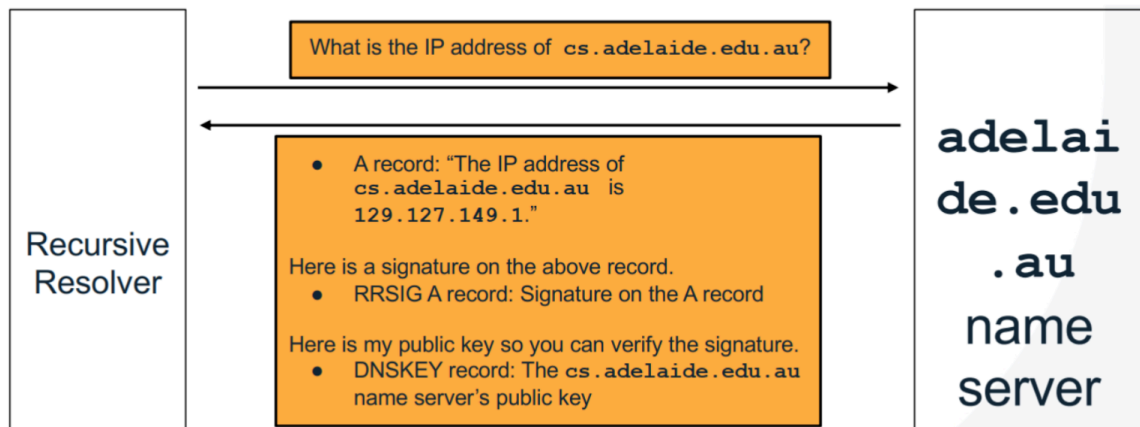
- I don't know the final IP, but ask the .au name server
- The root name server will give
 - NS record = which server handles **.au**
 - A record = IP address of the .au name server
 - DS record = fingerprint/hash of .au public key
 - RRSIG DS = signature proving the DS record is valid
 - DNSKEY = root public key
 - Basically Meaning
 - I trust the **.au** name server. Here is proof so you can verify it.



2. Ask the .au name server

- Now the recursive resolver asks the .au name server
 - "What is the IP address of cs.adelaide.edu.au?"
- Then the .au name server says:
 - "I. don't know the final IP, but ask the edu.au name server."
- Then .au name server will give
 - NS record = which server handles edu.au
 - A record = IP address of the edu.au name server
 - DS record = fingerprint/hash of edu.au public key
 - RRSIG DS = signature proving the DS record is valid

- DNSKEY = .au public key
- Basically meanings
 - "Since you now trust .au, you can use .au to verify and trust edu.au."



3. Ask the adelaide.edu.au name server

- Now the recursive resolver reaches the relevant domain server
- This time the adelaide.edu.au name server knows the answer
- It replies

A record:
cs.adelaide.edu.au = 129.127.149.1

- It also gives:

RRSIG A record = signature on the A record
DNSKEY = public key used to verify the signature

- Meaning
 - "Here is the actual IP address, and here is the signature so you can check this answer was not forged."

Full flow

Recursive resolver
→ Root server

“Ask .au, and here is proof .au is trusted.”

→ .au server

“Ask edu.au, and here is proof edu.au is trusted.”

→ adelaide.edu.au server

“The IP of cs.adelaide.edu.au is 129.127.149.1, and here is proof this answer is genuine.”

- **DNSSEC lookup = normal DNS lookup + signatures at each level to prove the answer and next server are trustworthy.**

WiFi Security - Introduction

- WiFi is a wireless local area network, based on the IEEE 802.11 standard
- Because WiFi uses radio signals, attackers nearby may try to capture or attack the traffic.
- Wifi needs security protocols

Type	Meaning	Security level
Open	No password / no encryption	Very weak
WEP	Old WiFi encryption	Broken / insecure
WPA	Improved replacement for WEP	Better, but old
WPA2	Stronger common WiFi security	Common, but still attackable with weak passwords
WPA3	Newer WiFi security	Stronger than WPA2

WEP (Wired Equivalent Privacy)

- WEP was meant to encrypt WiFi traffic but its design is weak, so attackers can crack the key very quickly.

Slide point	Simple meaning
WEP = Wired Equivalent Privacy	Old WiFi encryption standard
Uses RC4 stream cipher	It uses a stream cipher to encrypt WiFi traffic
24-bit unencrypted IV (Initialization Vector)	The IV is too short and visible, so it repeats often

Slide point	Simple meaning
104-bit fixed key	The main secret key stays the same
Using ARP to generate key stream	Attackers can create/capture lots of repeated traffic to collect enough data
Retired in 2004	WEP is no longer considered safe
Keys cracked in minutes	Attackers can recover the WiFi key quickly

- ARP is used to help collect enough encrypted traffic to crack the WEP key
- Not because ARP directly gives the key, but because
 - ARP packets are common, small, and predictable, so attackers can use them to generate many encrypted packets under different IVs

WPA2

- WiFi security protocol that uses cryptography to protect wireless communication
 - Make sure only people with the WiFi password can join
 - Messages over WiFi are encrypted
 - People without the WiFi password cannot easily read the traffic

Slide point	Meaning
Everyone with the WiFi password can join	The password controls access to the network
Messages are encrypted with keys	Traffic is protected so outsiders cannot easily read it
Attacker without WiFi password cannot learn the keys	Without the password, attacker should not be able to decrypt the WiFi traffic

- WPA2 is much stronger than WEP, but if the WiFi password is weak, attacker can try a dictionary attack
- Dictionary attack
 - Attacker tries many likely passwords from a list

```
password123
qwerty123
adelaide2026
```

```
iloveyou  
admin123
```

- If the WiFi password is weak or common, the attacker may guess it
- Attacker does not usually try to break the WPA2 encryption
- They try to guess the WiFi password
- If they guess the correct password, they can derive the encryption keys and access/decrypt traffic

More Weakness from WPA2

- Offline attack on WPA2-PSK
 - Attacker can capture WiFi handshake data, then try guessing the password offline on their own computer
 - They do not have to keep interacting with the WiFi router for every guess
- KRACK attack
 - Key Reinstallation Attack
 - Attacker attack the WPA2 handshake process. It could make devices reuse encryption keys in a unsafe way

WPA3

- Newer and supposed to be harder to attack than WPA2
- Improves password-based WiFi security and makes offline password guessing harder
- But it is still not perfect
 - Dragonblood attack
 - Attack against WPA's password/authentication design

Firewall and perimeter security

- A firewall acts like a controlled gate between the internet and an organisation's internal network

- Traffic should pass through the firewall so it can be checked against security rules
- Firewall decide
 - Allow, Block or log/monitor the traffic
 - Firewall controls the traffic based on a policy

Type	Meaning	Example
Inbound policy	Controls what can enter the network	Allow web traffic to company website, block unknown remote access
Outbound policy	Controls what can leave the network	Block malware from connecting to command-and-control servers

- Why it matters
 - Without a firewall, internal systems maybe directly exposed to the internet

Three types of firewalls

Stateless firewall / packet filter

- This is the simplest type
- Checks each packet individually, mainly using header information such as

```
source IP
destination IP
source port
destination port
protocol
```

- Does not remember the full TCP session
- Pros
 - Fast
- Cons
 - Can miss attacks because it does not understand the full conversation/session

Stateful Firewall

- This firewall remembers the connection/session
 - It checks

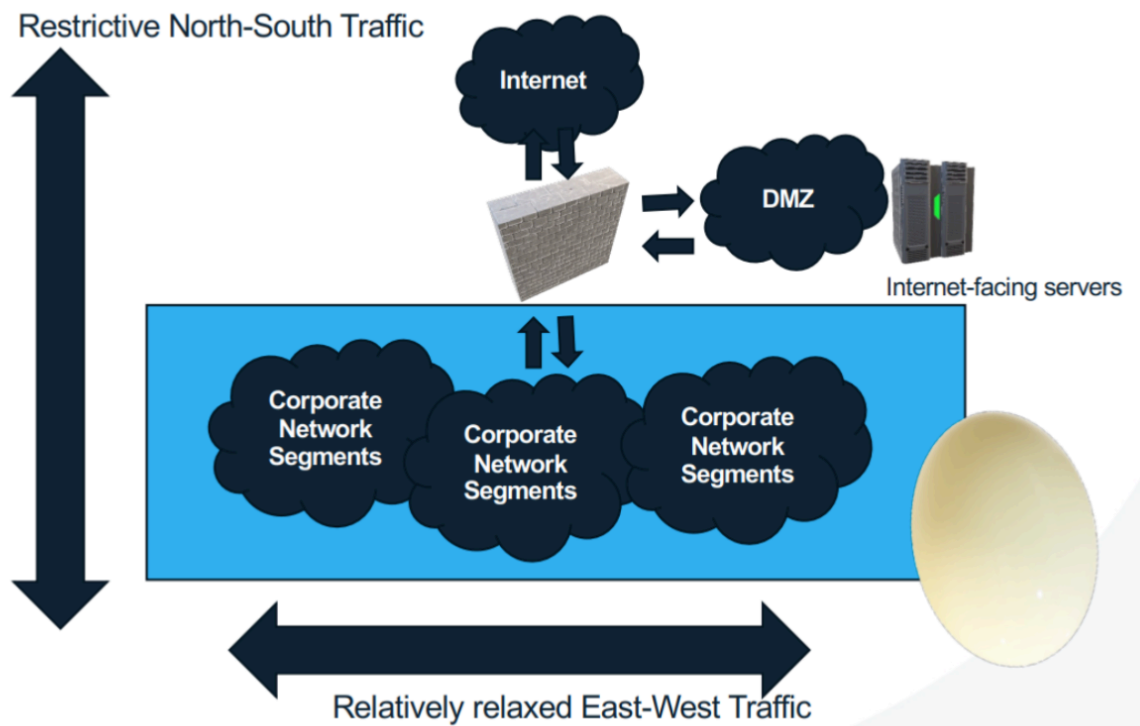
Is this packet part of an existing valid connection?
Was the TCP handshake completed?
Does this packet match the session state?

- So it understands the traffic conversation, not just one packet
- Pro
 - Detects more attacks than stateless filtering
- Con
 - Slower and more expensive because it tracks session state

Application / Layer 7 proxy firewall

- This firewall looks at application-level content
 - Example: Web traffic
 - Firewall checks
 - HTTP requests
 - URLs
 - cookies
 - forms
 - SQL injection patterns
 - malicious payload
- So the application-level firewall will look inside the application data, not just IPs and ports

Traditional Segmentation



- Protects the outside boundary strongly, but the inside network is more relaxed
- The firewall mainly controls traffic going in and out of the segmentation

Term	Meaning	Example
North-South traffic	Traffic between internal network and outside internet	User accessing a website; external user accessing company web server
East-West traffic	Traffic moving inside the internal network	One internal server talking to another internal server

- DMZ = Demilitarized Zone
 - Separate network area for internet-facing servers, such as
 - public website server
 - email server
 - VPN server
 - Public facing servers are separated from the internal corporate network
 - So when the public web server is compromised, the attacker should not immediately reach the internal network
- Weakness of Traditional segmentation

- Traditional segmentation only assume
 - Outside is dangerous
 - Inside is safe
- This is no longer suits for the modern security as attackers can get inside through phishing, malware, stolen accounts, or compromised devices.

Microsegmentation

- Microsegmentation divides the internal network into smaller protected sections, so if one system is compromised, the attacker cannot easily move everywhere.
- This solves the problem from the Traditional segmentation problem
 - As the TSP only protects the outside traffic, and might go easy on the inside traffic
- Microsegmentation creates more detailed rules between internal system
 - Example

```
Web server can talk to database server
HR computer cannot talk to finance database
Student system cannot talk to payroll server
```

- If an attacker compromises one machine, microsegmentation can trap them in a small area

Server to server granular policies

- Instead of being general of internal network can talk to internal network
- Microsegmentation is better in defining more detailed rules such as

```
Server A can only talk to Server B on port 443
Server C cannot talk to Server D
Database only accepts traffic from the web server
```

Zero-trust

- Do not automatically trust a device just because it is inside the network
 - Any endpoint could be compromised, so every connection should be checked and limited

Network Intrusion Detection/Prevention (IDS/IPS) Systems

- IDS/IPS = systems that monitor network traffic or logs to find possible attacks
- There are three detection methods

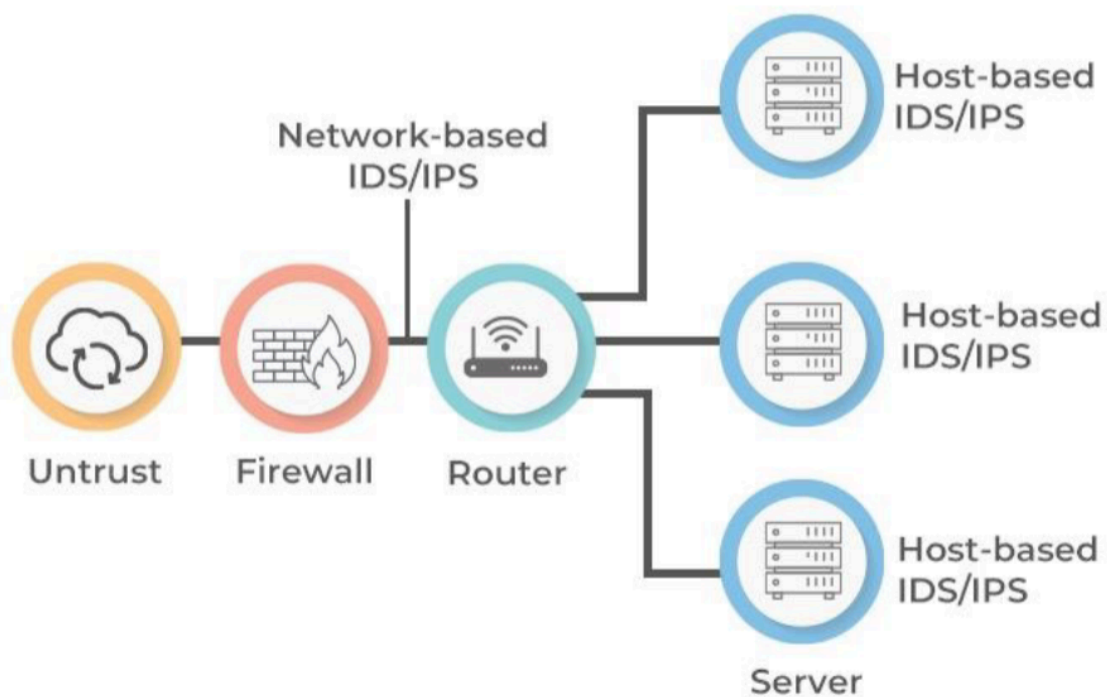
Method	Meaning	Easy example
Signature-based detection	Detects known attack patterns	Like antivirus detecting a known malware signature
Anomaly-based detection	Detects unusual behaviour	A user normally logs in once per day, but suddenly tries 500 logins
Stateful protocol analysis	Checks whether network protocol behaviour is normal	HTTP, DNS, TCP traffic should follow expected rules; abnormal protocol use may be suspicious/

IDS = Intrusion Detection System

- It only detects and alerts
- It is usually passive, meaning it watches traffic but does not block it

IPS = Intrusion Prevention System

- Detect and block suspicious traffic
- Usually inline, meaning the traffic must pass through it before reaching the destination



Network-based

- The Network-based IDS/IPS sits on the network, often near the firewall/router. It watches traffic moving across the network

Host-based IDS/IPS

- Runs on individual servers or computers. It watches activity on that specific machine, such as logs, file changes, processes, or suspicious behaviour.

Example:

- Snort
 - IDS/IPS tool
- It can inspect network traffic and detect suspicious patterns

Week 8 Web Application Security

URL: Uniform resource Locator

URL: Domain and Path


```
https://myuni.adelaide.edu.au/courses/95262
```

- The domain tells the browser which web server to contact
- In this example

```
myuni.adelaide.edu.au
```

- This tells the browser should contact the MyUni Adelaide Server

Domain = which website/server

- The domain is located after https:// and before the next /

Path

- Tells the server which page/resource/file you want
- in this case it is /courses/95262

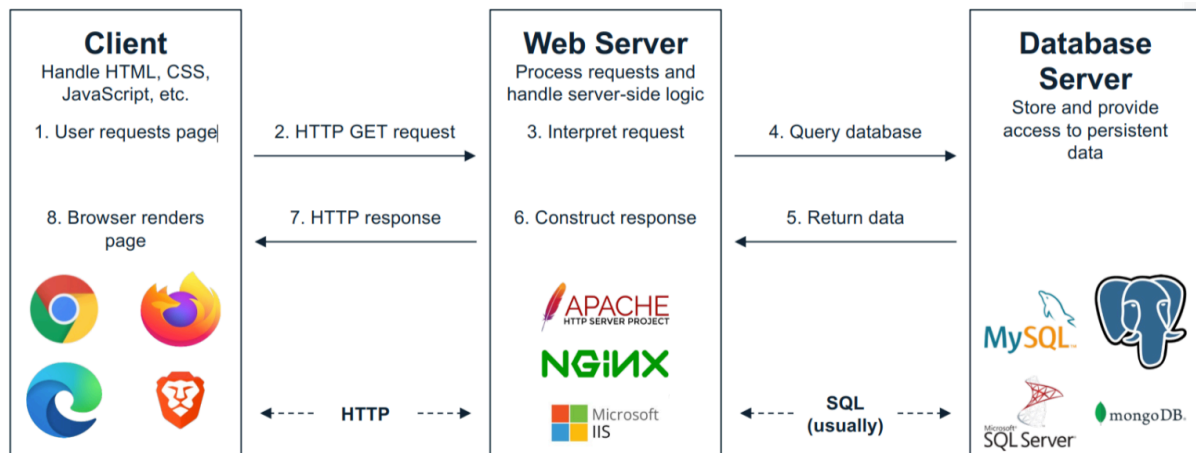
URL: Query

- Query is optional and located after a question mark

```
?is_announcement=true
```

- The query gives extra information/argue
- It gives arguments to the web server as name=value pairs.
- Multiple arguments are separated by &
- Query values are important in security because attackers can modify them

Web Services



- The client side handles
 - HTML, CSS, JavaScript
 - The browser is responsible for showing the webpage to the user
- Web Server
 - The web server receives the browser's request and processes it
 - Apache
 - Nginx
 - Microsoft IIS
- Database Server
 - Database server stores data permanently
 - MySQL
 - SQL Server
 - mongo DB
- Proper Flow
 1. The user requests a page in the browser
 2. The browser sends an HTTP GET request to the web server
 3. The web server interprets the request
 4. The web server queries the database, usually using SQL
 5. The database returns the requested data
 6. The web server constructs the response page.

7. The web server sends an HTTP response back to the browser
8. The browser renders/displays the page

HTTP Data Flow in a Simple 3-Tier Application

- A web application usually has 3 tiers
 1. Client
 - The browser, such as Chrome or Firefox. It sends requests and display pages.
 2. Web Server
 - Handles HTTP requests, runs server-side logic, and prepares responses
 3. Database Server
 - Stores data and responds to database queries
- Step-by-step flow
 1. Browser sends GET request
 - A GET request is usually used to request/read a page or data
 - Such as GET /courses/95262
 2. Server sends Set-Cookie
 - Help the browser to store a cookie
 - A cookie can be used to remember session information, such as whether the user is logged in
 3. Browser sends GET + parameters
 - Later, the browser sends another request with parameters
 - Such as GET /search?keyword=security
 3. Server queries database
 - The webserver than may ask the database for data
 4. Database return data
 - The database sends the requested data back to the web server
 5. Web server returns formatted data

6. Browser sends POST + data
7. Server updates database
8. Success or fail response

Cookies



- A cookie is a small piece of data that a web server sends to the browser
- The browser stores it and sends it back to the server in later requests
- Cookie is needed
 - HTTP is stateless
 - Server does not automatically remember previous requests
- Cookie works
 - The browser sends a request to the server
 - Then the server replies with a Set-Cookie header
 - The browser stores the cookie
 - In later requests, the browser sends the cookie back using the Cookie header

```
//Browser Header  
Cookie: session_id=abc123
```

Main use of cookies

- Session management
 - Used for logins, shopping carts, and anything the server needs to remember
- Personalisation
 - Used for user preferences, themes, language settings, and other custom settings
- Tracking
 - Used to record and analyse user behaviour

Tools for analysing Web Applications

Local Proxy Tools

- Local proxy tools are used to **intercept, record, pause, and modify HTTP requests** between the browser and the web server.
- Examples
 - Burp Suite
 - OWASP ZAP
 - Fiddler
- Proxy Tools allow
 - Capture requests
 - Record responses
 - Pause requests
 - Modify requests before sending
 - Repeat requests for testing
- Example: A website may have a form field that is hidden or read-only in the browser

- But with proxy tool, the tester can still modify the HTTP request directly before it reaches the server
- Security point
 - Front-end validation is not enough
 - JavaScript might stop a user from entering invalid input in the browser. But an attacker can use Burp to change the request after the browser validation.
 - Therefore the server must always validate the input again

Proxy Functions in Security

- A proxy tool helps testers capture, inspect, modify, and resend web requests between the browser and the web server.
- Main functions
 - Proxy
 - Captures and modifies web traffic while it is being sent
 - User can change parameters, cookies, headers or form data before the request reaches the server
 - Repeater
 - Repeats a GET or POST request for testing vulnerabilities
 - Intruder
 - Uses different payloads to test parameters automatically
 - Spider
 - Automatically follows links on a website to discover pages
 - Finding pages like /login, /admin, /profile, or /settings
 - Spider follows links automatically and builds a map of pages it can reach
 - Scanner
 - Automatically looks for possible security weaknesses
 - It can passively by observing traffic, or actively by sending test requests

- Audit
 - Looks for hidden directories and files
 - such as /admin, /backup

OWASP (OPEN WEB APPLICATION SECURITY PROJECT)

OWASP TOP 10 -2025

- This is important as many common attacks such as injection attacks, come from poor input handling and weak web application design.
- Provides rankings and remediation guidance for web application security risks

No.	Risk	Simple meaning
A01	Broken Access Control	Users can access data/functions they should not.
A02	Security Misconfiguration	Bad settings, default configs, exposed services, verbose errors.
A03	Software Supply Chain Failures	Unsafe/outdated dependencies, packages, build tools, or third-party code.
A04	Cryptographic Failures	Sensitive data is not properly protected by encryption, hashing, or TLS.
A05	Injection	User input becomes code/query, such as SQL injection or command injection.
A06	Insecure Design	Security weakness exists in the system design, not just the code.
A07	Authentication Failures	Login/session problems, weak authentication, poor credential handling.
A08	Software or Data Integrity Failures	Software updates, code, or data cannot be trusted or verified.
A09	Logging and Alerting Failures	Attacks are not properly logged, detected, or alerted.
A10	Mishandling of Exceptional Conditions	Errors/exceptions are handled badly, causing crashes, leaks, or insecure behaviour.

SQL Injection

- SQL injection happens when the user input is inserted into the SQL query without proper validation or protection
- There are four common SQL injection outcomes

' Or 1 = 1— authentication bypass

```
SELECT * FROM users  
WHERE username = 'input' AND password = 'input';
```

How it works:

- 1=1 is always true, so the database may return a valid user even without the correct password
- - - comments out the rest of the SQL query

UNION query data leak

- Union combines results from two SQL queries
- An attacker may use it to make the database return data from another table

```
SELECT name, price FROM CATALOGUE WHERE id=$id
```

- Then if the user input is 123, then the query normally becomes:

```
SELECT name, price FROM CATALOGUE WHERE id=123
```

- But when the attacker change the input from 123 to

```
1 UNION SELECT name, password FROM users#
```

- Then the SQL query becomes

```
SELECT name, price FROM CATALOGUE WHERE id=1  
UNION SELECT name, password FROM users#
```

- # is comment to tell the database to ignore everything after this point

- The attacker is forcing the database to return two sets of result

Original query: item name + item price
 Injected query: username + password

Batched SQL

- Batched SQL means the database accepts more than one SQL command in one input/request
- Some databases allow SQL commands to be separated using semicolon
- Such as

```
SELECT name FROM Students;
DROP TABLE Students;
```

- Example:

```
SELECT name FROM Students
WHERE first_name = '$input' AND active = true;
```

- The Websites expects to user to enter a normal first name
- But if the attacker enters

```
Robert'); DROP TABLE Students;--
```

- Then the query becomes

```
SELECT name FROM Students
WHERE first_name = 'Robert'); DROP TABLE Students;--' AND
active = true;
```

- Then the back end will happen

```
Robert')           closes the original input
;                  starts a second SQL command
DROP TABLE Students deletes the Students table
```

```
--          comments out the rest of the original  
query
```

- Attacker is not just changing the original query, they also added a new SQL command

Blind SQL injection

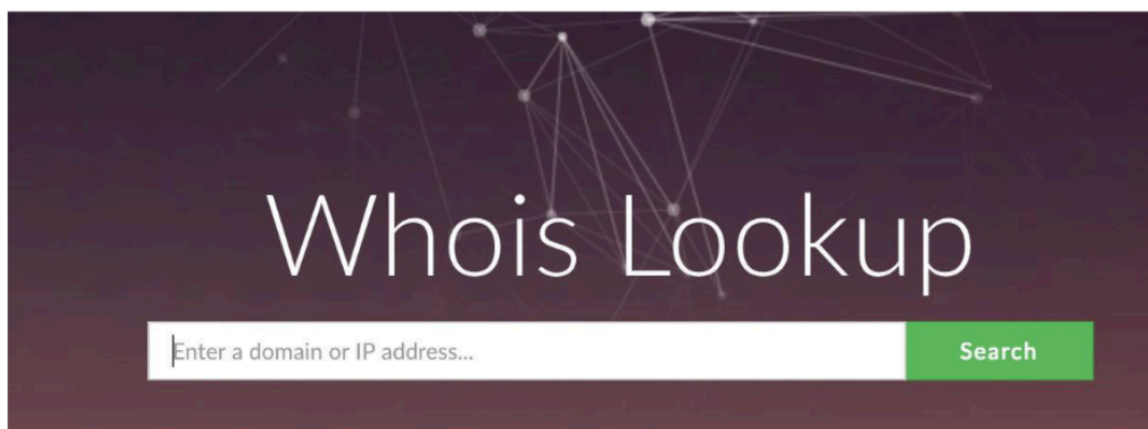
- Happens when the attacker can inject SQL, but cannot directly see the database result on the page
- The attacker cannot see the database output directly, but they can observe clues, such as

Page loads normally
Page shows an error
Page takes longer to respond
Login succeeds or fails
Different message appears

Command Injection

- Attacker injects operating system commands
- such as

```
example.com; cat /etc/passwd
```



Injection Attack and Defence

Attack

- Command Injection
- SQL injection
- XSS but it attacks the browser not the server

Prevention

- Input validation / Whitelisting
 - Only allow expected input format
- Parameterised queries (For SQL injection)
 - Prepared statement

```
SELECT id, username
FROM users
WHERE username = ? AND password = ?;
```

- Prevent SQL injection by separating SQL code from user input
- Use safe API
 - Use safer database libraries, such as PDO for MySQL/PHP

Week9 Digital Forensics and Malware Analysis

DFIR: Digital Forensics and Incident Response

- Identifying Cyberattacks
- Investigating What happened
- Collecting Evidence
- Helping fix/remediate the issue

Why DFIR important

- Modern organisations have many endpoints, systems, logs, users and attacks.
- When something goes wrong, organisation need evidence to answer:
 - What happened?
 - When did it happen?
 - Who or what caused it?
 - What systems were affected
 - How can we stop it happening again

CIRT

CIRT = Cyber Incident Response Team

- Computer Incident Response Team
 - The team is responsible to respond to
 - Security Breaches
 - Viruses
 - Other potentially catastrophic incidents that face significant security risks
 - Digital Forensics provides necessary information and evidence that the computer emergency response team needs

What is Forensics

- Forensics means applying scientific principles to evidence
- In cybersecurity
 - Digital forensics is the investigation of digital evidence to test what happened during a cyber incident
 - It is not about guessing, it is using evidences

Phases of the Forensics Process

Collection

- Collect possible evidence

- Disk image
- memory dump
- log files
- PCAP files
- suspicious executable

Examination

- Extract relevant data from the evidence
 - Filter Wireshark traffic
 - extract files from PCAP
 - search logs
 - Inspect file metadata

Analysis

- Understand what the evidence means
 - attacker downloaded malware
 - user clicked phishing link
 - malware connected to command-and-control server

Reporting

- Explain findings clearly
 - timeline
 - affected systems
 - evidence found
 - recommendation

Forensic Areas of Practice

- File System Forensics
- Malware Analysis
- Memory Forensics

- Network forensics
- Cloud Forensics
- Mobile Forensics
- Log Analysis
- IoT Forensics

CTF vs Real World Forensics

CTF - Forensics

- Focuses on puzzles, using methods like below to find the flag
 - File format analysis
 - Steganography
 - Memory dump analysis
 - network packet capture analysis
 - Examine and process a hidden piece of metadata information out of static data files

Real-World Forensics

- Focuses on finding evidence of real malicious activity, focusing on where to find incriminating clues.
 - Attacker traces
 - Insider threat behaviour
 - Suspicious Logs
 - Malware execution
 - Unusual network connections
 - Registry / File system changes

Logs for Digital Forensics

- System Logs
 - Operating system events, errors, and other activities related to the operating system

- system errors
 - service start/stop
 - crashes
- Application Logs
 - Track user activities and errors specific to applications
 - Web server access logs
 - Database error logs
- Security Device Logs
 - Record events from devices designed to protect the network, such as firewalls and intrusion detection system
 - Firewall logs
 - IDS/IPS alerts
- Authentication Logs
 - Document attempts and statuses of user logins, including successful and failed authentication attempts
 - Successful login
 - Failed login
 - unusual login time
- Network device logs
 - Logs from routers and switches detailing system operations and network traffic flow
 - Network traffic flow
 - Device status
- Audit Logs
 - Keep a record of changes made within the system, especially changes to configurations or policies
 - Configuration change
 - Policy change
 - Permission change

Network Forensics

Packet Traces

- Contain all the information being sent across a network
 - source IP
 - destination IP
 - protocol
 - actual data sent

Network packets capture

- Software method
 - Using Wireshark or tcpdump
 - Can be captured into a PCAP file
- Hardware method
 - Network tap
 - A physical device palced between two network devices
 - The tap copies the traffic passing between them and sends a copy to the capture machine
- Port mirroring → A feature on a networks switch
 - Normally, a switch only sends traffic to the correct destination port

PC A traffic → only goes to PC B

- So the monitoring device will not be able to see
- But with port mirroring, the switch is configured to copy traffic from one port to another port

PC A traffic → PC B
↳ copy to Wireshark laptop

- Wireless sniffing → Capture the Wifi traffic

- Wireless adapter listens to Wi-Fi traffic
 - The network is open/unencrypted
 - Have Wifi key
 - The adapter supports monitor mode

Network packet traces : Examination and Analysis

- A PCAP may contain thousands or millions of packets
 - But only a few are important
 - Use Wireshark to filter, inspect, and analyse the useful packets

Network Logs

- Records of network events (something happened over the network)
- Do not contain the actual data that was sent
 - Such as Firewall log
 - source IP
 - Destination IP
 - port
 - allowed/blocked
 - But actual content may not be included

Steganography

- "Art and Science of communication in a way that hides the existence of a message"
 - Hiding a message inside something else so people do not even notice the message exists
 - Encryption hides the meaning of a message
 - Steganography hides the existence of the message
- Example
 - A normal-looking image contains the hidden message
 - People may not even realise there is a message

- Send a picture of a cat, but secretly the file contains secret information

Signal or pattern imposed on content

- Hidden message is added into the original file somehow
- For example, in a image, every pixel has colour values:

```
Red:    10101100
Green:  11001010
Blue:   11100011
```

- A steganography technique may slightly change the last bit of the colour value to store secret data

Persistent under transmission

- Hidden message should survive when the file is sent or moved
 - If I hide a message inside an image and then send it by email, the hidden message should still be inside the image after the receiver downloads it
- This is important because some platforms compress or modify images

“Not Encryption - original image/file is intact”

- Steganography does not necessarily encrypt the message
- The original image or file still opens normally
- But inside the file, there may be hidden content

Technique	What it does
Encryption	Scrambles the message so it cannot be read
Steganography	Hides the message inside normal-looking content

Not fingerprinting

- Fingerprinting is more about creating a separate identifying record of a file
 - Such as File hash
 - The hash describes or identifies the file, but it is separate from the content

- Fingerprinting leaves a separate file describing contents

Why steganography matters in cybersecurity

- Steganography can be used for both legitimate purposes and malicious purposes because it hides data inside normal-looking content
- Often appears in CTF challenges because it is good for hiding flags

Industry's desire to protect copyrighted digital work

- Companies may hide information inside digital files to prove ownership
 - Example: A photographer uploads an image online.
 - They may embed hidden data into the image such as

```
Author ID: John Smith  
Copyright ID: 12345
```

- If someone steals the image, the hidden data can help prove the original owner

Detect counterfeit, unauthorized presentation, embed key, embed author ID

- Detect counterfeit
 - Check whether a digital file is fake or copied
- Unauthorised presentation
 - Detect if someone uses media without permission
- embed key
 - Hide an identifying key inside the file
- embed author ID
 - Hide the creator's identity inside the file

Convert way to distribute malware

- An attacker may hide malicious code or data inside a normal-looking file
- So that when the victim downloads it, the file may contain

- Malicious script
- Malware payload
- command data
- encrypted instructions
- People normally trust image files

Convert way to exfiltrate data

Upload harmless images with embedded data

- Exfiltrate means secretly take data out
 - A malware-infected company computer steals customer data
- Malware hides the data inside normal images and uploads them
 - such as - cat_photo.png
 - To a security team, it may look like normal image uploads
 - But actually, the image contain stolen data
- Attackers can hide stolen information inside harmless-looking files to avoid detection.

Network steganography

- Hiding data inside normal network communication
 - An attacker hides secret data inside
 - Packet timing
 - unused header fields
 - DNS queries
 - ICMP packets
 - HTTP traffic patterns

Steganography ≠ Copy protect ≠ Cryptography

Concept	Main purpose	Example
Steganography	Hide the existence of data	Hide text inside an image

Concept	Main purpose	Example
Cryptography	Hide the meaning of data	Encrypt message into ciphertext
Copy protection	Stop unauthorised copying/use	DRM (Digital Rights Management) on movies/games. (Prevent copying a Netflix video or game file)

Steganalysis

- Detecting hidden data or message, or prove it exists

Discovering and rendering useless convert steganography messages

- Discover whether hidden data exists
- Render it useless, meaning remove it, damage it, or make it unreadable
- Example
 - Attacker hides stolen data inside
 - cat_photo.jpg
 - Security may use steganalysis to detect that the image has hidden content
 - Then they may recompress, strip or modify the file so the hidden data cannot be recovered
- Steganalysis is not only finding hidden messages, but also stopping them from being useful

Analysis of the carrier file

- The carrier file means the normal-looking file that carries the hidden data

Simpler steganographic techniques produce changes in file size, statistics or both

- Basic hiding methods often leave clues
 - Example: Hides a PDF inside an image by appending it to the end, the image may become unusually large
- If a normal image, pixel colors have natural patterns.

- If hidden data is inserted into the least significant bits
- The pixel data may become statistically strange, even human eyes cannot see.

Color variations, loss of resolution and other distortions visible to the human eye

- Some weak steganography changes the image enough that you can actually see something wrong
 - Strange colour noise
 - blurry areas
 - blocky patterns
 - weird pixels
 - reduced image quality
- This is usually happen for simple or badly done steganography

Requires that you known what the original carrier image or file should look like

- If have the original clean file, detection becomes easier
 - file size changed
 - some pixel values changed
 - hidden data was appended
 - metadata changed

Malware Analysis

- Malicious Software
- Types of Malware

- **Virus**
- **Worm**
- **Trojan**
- **Spyware**
- **Keylogger**
- **Botnet**
- **Remote Access Trojan (RAT)**
- **Banking Malware**
- **Point of Sale (PoS) Crypto-miner**
- **Adware**
- **Rootkit**
- **IoT**
- **and more...**

Malware Distribution

- Largely depends on social engineering, attackers trick users into opening, clicking, or plugging something in

Method	Simple explanation	Example
Email attachments	Malware is attached to an email	Fake invoice <code>.docx</code> or <code>.exe</code>
Phishing links	User clicks a malicious link	Fake login page or malware download page
Malicious websites	Website automatically tricks/downloads malware	Fake software update page
Infected storage devices	Malware is placed on USB/storage devices	USB left in public for someone to plug in
Network propagation	Malware spreads through the network	Worm infects other vulnerable machines

- Worms are different, they do not require victim action and can spread automatically through networks if vulnerable system exist

Malicious Adversary Motivation

- Malware is usually created for a purpose
- Most common motivation is illegal profit

Motivation	Simple explanation	Example
Money	Most malware aims to make illegal profit	Ransomware demanding payment
Curiosity / prank	Early malware was sometimes made for fun or experimentation	A virus showing a joke message

Motivation	Simple explanation	Example
Insider revenge	A current/former employee attacks an organisation	Deleting company files after being fired
Hacktivism	Malware used for political or social causes	Defacing a website to send a message
Espionage	Stealing sensitive information	Nation-state stealing government or corporate secrets
Weak law enforcement	Cybercrime grows where laws are not strongly enforced	Criminal groups operating with low risk

Reverse Engineering

- Taking something apart to understand how it works
 - Break something down into smaller parts to understand it
- To understand its working in details
 - What functions does it call
 - What files does it create
 - What network connections does it make
 - Does it steal data
 - Does it hide itself.....
- Reverse engineering is important in cybersecurity
 - Vulnerability Discovery
 - Discover vulnerabilities in software when the source code is not available
 - Malware Analysis
 - Understand malware behaviour
 - Static analysis and dynamic analysis

What does it mean to learn Malware reverse engineering

- It is like learning a language
- Vocabulary = assembly instructions, like mov, cmp, jmp, call

- Grammar = how those instructions are structured, including addressing modes and ABI convention
- Idioms/expressions = common compiler patterns or optimisation patterns
- ABI → Application Binary Interface
 - A low-level convention that defines how compiled code interacts with the CPU, operating systems, and other code.
 - In reverse engineering, ABI conventions are like the "grammar" of compiled programs
 - They help analysts understand how functions use registers, stack memory, parameters, return values, and functions calls when reading assembly code

Assembly Language

- When source code is not available, analysts may need to read assembly to understand what a program is doing
- Assembly is close to what CPU actually understands
 - Is a lower-level language
 - Human-readable
- Analysts convert machine code into assembly to make the program easier to inspect
- Intermediary step between higher-level code and machine code

C source code → Assembly → Machine code → Executable `file`

- In reverse engineering, going backwards

Executable `file` → Assembly / decompiled code → Understanding behaviour

Large variety of assembly languages

- Different CPU architectures have different assembly languages

Architecture	Common use
x86 / x86-64	Windows/Linux PCs
ARM	Phones, tablets, IoT, Apple Silicon
MIPS	Routers/embedded systems
RISC-V	Some modern/experimental systems

RE without Source Code

- Reverse Engineering can still be done even when the original source code is not available
- This is common because attackers usually only leave behind the compiled file
 - .exe
 - binary executable
- Normal software process
 - When a developer writes software, the process is usually

Stage	Meaning
Source code	Human-written code, such as C or C++
Compiler	Converts source code into machine code
Executable file	The final program that the computer can run

- Reverse Engineering process
 - Executable → Disassembler → Assembly
 - Executable → Decompiler → Pseudocode

Disassembler

- Converts **machine code/binary** into assembly language
- Assembly is low-level but close to what the CPU actually runs
- Useful when analysts need to see exact instructions

Decompiler

- Converts **machine code/binary** into higher-level pseudocode

- Easier to read than assembly
- Example
 - Ghidra may show C-like code, but it will not perfectly restore the original source code

Malware Analysis Fundamentals

- Source code
 - The programming language
- Compiled code
 - Source code goes through a compilation process, and it is transformed into machine code that consists of binary instructions
- Machine Code
 - Directly executed by the hardware and is a sequence of binary digits of 0s and 1s that represent specific instructions, but when viewed it is often hexadecimal
- Assembly Language
 - Low-level programming language that provides a symbolic representation of the machine code instructions.

Term	Meaning	Simple example
Source code	Human-written programming code	C, C++, C# code written by developer
Compiled code	Source code after being converted by a compiler	<code>.exe</code> file created from C code
Machine code	Binary instructions directly executed by hardware	0s and 1s, often viewed as hex
Assembly language	Human-readable symbolic form of machine code	<code>mov</code> , <code>cmp</code> , <code>jmp</code> instructions

Static Malware Analysis

- Analyse the malware without running it
- Safer as the suspicious file is not executed
- The goal is to find clues about what the malware may do

Method	Meaning	Simple example
File analysis	Check file type, header, format, and structure	Is it really a <code>.jpg</code> , or actually an <code>.exe</code> ?
String analysis	Look for readable text inside the file	URLs, IP addresses, commands, file paths
Disassembly	Convert machine code into assembly	Understand low-level instructions
Decompilation	Convert compiled code into C-like pseudocode	Easier to understand program logic as the program becomes more human readable

- Example of clues
 - suspicious IP addresses
 - domain names
 - URLs
 - file names
 - registry paths
 - commands such as `cmd.exe` or `powershell`
 - imported functions/APIs
 - signs of packing or obfuscation

Tools

Tool type	What it does	Simple example
Disassemblers	Convert machine code into assembly	Ghidra, IDA, radare2
Decompilers	Convert binary/assembly into C-like pseudocode	Ghidra decompiler
System call tracers	Show system/API calls used by the program	See if malware tries to open files or connect to network
Python libraries	Help inspect files or automate analysis	Parse PE headers, extract strings
Online tools	Analyse file reputation or metadata online	VirusTotal-style checking

Dynamic Malware Analysis

- Running the malware in a controlled environment
- The goal is to observe what the malware actually does
- It is riskier than static analysis, should be done in sandbox

Method	Meaning	Simple example
Sandbox analysis	Runs malware in an isolated environment and records behaviour	Malware creates files or connects to a suspicious IP
Debugging	Runs malware step by step in a debugger	Analyst checks which branch/function is executed
Dynamic Binary Instrumentation (DBI)	Monitors or modifies program execution very precisely while it runs	Track every function call or memory access

Tools

Tool type	What it does	Simple example
Debuggers	Run program step by step	Check which branch or function runs
System call tracers	Monitor calls while program runs	See file, registry, network actions
Sandbox	Runs malware in isolated environment	Observe created files and network traffic
DBI (Dynamic Binary Instrumentation)	Deeply monitors/modifies execution	Track instructions, memory, function calls
Online tools	Run/scan samples in cloud environments	Online sandbox reports behaviour

Ghidra

Point	Simple explanation
Java-based tool	Ghidra runs using Java
Developed by NSA	Created by the US National Security Agency
Similar to IDA Pro / Binary Ninja	It has similar reverse engineering features

Point	Simple explanation
Static analysis	Mainly used to inspect binaries without running them
Cross-platform	Runs on Windows, Linux, and Mac
Open source	Released publicly as open source in 2019

Remedy

- How organisations defend against malware and respond after malware is detected
- Remedy → controls or actions used to prevent, detect, block and investigate malware

Remedy	What it does	Simple example
IPS	Blocks suspicious/malicious traffic automatically	Stops known exploit traffic before it reaches server
IDS	Detects suspicious traffic and raises alerts	Alerts SOC about possible malware connection
Antivirus	Detects/removes known malware on endpoints	Quarantines infected <code>.exe</code>
Firewall	Controls allowed/blocked network traffic	Blocks unknown inbound connections
DMZ / Proxy	Separates and filters internet-facing traffic	Web server placed in DMZ, proxy filters web access
AI malware detection	Uses behaviour/patterns to detect malware	Detects unusual file encryption behaviour
SOC / Incident response team	Investigates and responds to incidents	Isolates infected machine and resets accounts
Forensic analysis	Finds evidence and reconstructs what happened	Checks logs, malware sample, PCAP, disk image

- However, with all these remedies, malware is still difficult to stop
 - Malware keeps changing, organisations should not rely on only one defence

Point	Simple explanation	Example
Significant disruption	Malware can seriously affect business operations	Ransomware shuts down hospital or company systems

Point	Simple explanation	Example
Constantly evolving	Malware changes to avoid detection	New variants bypass old antivirus signatures
Criminal business model	Cybercrime can be organised and profitable	Ransomware-as-a-Service
Static and dynamic analysis	Malware can be studied without running it or by running it safely	Strings analysis vs sandbox analysis
Combined defences	One tool is not enough	Use antivirus + firewall + IDS/IPS + SOC + forensics

Week 10 Security Engineering, Operations, and Management

Security Engineering

- Security engineering means building systems that remain dependable even when facing attacks, mistakes, or failures
- Security should be considered early in system design, because fixing security problems later is more expensive
- Security is cheaper and easier to build in from the start than to patch later

Security Design Principles / Rules of thumb

1. Keep security simple

- Complexity creates more chances for mistakes
- Keep controls atomic

2. Make Security Usable

- Security controls must be easy enough for normal users to understand and follow
- If security is too confusing or annoying, users may ignore it or find unsafe shortcuts

Example	What it means
Old certificate warning vs newer browser warning	Security warnings should be clear and understandable
Password written on sticky note	If password rules are too hard, users may create insecure workarounds

3. Least Privilege

- Least privilege means users and programs should only have the permissions they need
- This limits damage if an account or program is compromised
 - User without local admin rights
 - If malware infects the user, it has limited permissions
 - Program running as non-root
 - If the program is exploited, attacker gets limited access
 - Command inject / Buffer overflow
 - These attacks are less damaging if the program has low privileges

4. Segregation of Duties

- Segregation of duties means splitting important tasks between different people or systems
- The goal is to stop one person from having enough control to commit fraud or make dangerous changes alone

Example	Meaning
Two-man rule	Very sensitive actions require two people to approve or perform them
Payment process table	One person updates vendor bank account, another approves payment, another transfers money
DEV → UAT → PRD	Developers should not directly move code into production

5. Defence in Depth

- Multiple layers of security, not relying on one control
- If one layer fails, other layers still can reduce damage

Layer	Simple explanation
System is patched	Fix known vulnerabilities before attackers exploit them
Secure coding	Reduce bugs such as injection or buffer overflow
Services running as non-root	Limit damage if a service is compromised
Web server running in DMZ	Isolate public-facing systems from internal network
Firewall and IDS	Block or detect suspicious traffic

- Defence in depth is not only about stopping attacks
- It also includes detecting attacks when prevention fails
- 100% prevention is not realistic or cost-effective

Layer	Purpose
Network gateway anti-malware	Scans traffic entering/leaving the network
Email gateway anti-malware	Scans email attachments and links
Workstation anti-malware	Protects user computers
File storage anti-malware	Scans stored files on servers

- Try use different vendors
 - As different vendors may detect different threats
- Example
 - Firewall + email filter + endpoint anti-malware + IDS + backups. If one control fails, the others can still reduce the impact

6. Zero Trust

- Zero trust means do not trust anything by default
- Every user, device application, input, third party should be checked or monitored
- It assumes that any part of the system could be compromised

Slide point	Simple explanation	Example
User inputs → validate	Never trust user input directly	Check form input before using it in SQL

Slide point	Simple explanation	Example
Third-party libraries → review	External code may have vulnerabilities	Review/pentest libraries before use
Third-party contractors → background check	External workers can create risk	Check contractor trustworthiness
Employees → background check + monitoring	Internal users can also be risky	Monitor unusual employee behaviour
Applications → firewall + monitoring	Apps should not be trusted automatically	Host-based firewall and logging

Zero Trust - No perimeter

- Old Security idea: Protect the inside network like a castle
 - However, cloud services, BYOD, remote work, and mobile devices mean there is no clear "inside" anymore
- Hence zero trust checks access continuously, even if the user is already inside the network

Zero Trust - Microsegmentation

- Microsegmentation
 - Splitting the network into smaller protected zones
 - If one area is compromised, the attacker cannot easily move everywhere
- example
 - HR system, finance system, and database are separated
 - Compromising one workstation does not automatically give access to all systems

Zero Trust - Fine-grained audit

- Keep detailed logs of who accessed what, when, from where, and what they did
- It is more detailed than just "user logged in"

Zero Trust - Adaptive security

- Security controls can change based on risk/context
- The system does not treat every login the same

7. Security by Default

- Systems should start in a safe configuration
- Users/admins should not need to manually turn on basic security

Example	Simple explanation
Turn off insecure devices	Disable unsafe services/features unless needed
SELinux enabled out of the box	Security protection is active by default
No default passwords	Devices should not use common passwords like <code>admin/admin</code>
Default deny firewall rule	Block traffic by default, only allow what is needed

8. Fail Securely

- When something goes wrong, the system should fail in a safe/locked-down state
- It should not accidentally allow too much access

Firewall approach	Meaning	Security result
Allow specific services, deny everything else	Only known safe traffic is allowed	Safer
Deny some bad services, allow everything else	Unknown traffic is allowed by default	Riskier

9. Avoid Security by Obscurity

- Security by obscurity means relying on hiding information as the main protection
- This is weak as attackers can eventually discover hidden details

Kerckhoff's principle

- The security system should still be secure even if attackers know how it works
- Only the secret key/password/private credential should need to stay secret

Bad thinking	Better thinking
"Our encryption is safe because nobody knows the algorithm."	"Our encryption is safe because the key is secret and the algorithm is strong."

- Example: SSH port
 - Running SSH on a non-standard port like 2211 is ok
 - This may reduce random scanning noise
 - But it should not be the main security control
 - As attackers can scan all the ports and find it
 - If SSH has weak passwords, moving the port does not really fix the risk
- Code obfuscation
 - Obfuscating code means making the code harder to read
 - This can slow attackers down, but it is not a real security
 - Attacker would eventually reverse it and analyse it
- Better approach
 - Use strong authentication
 - Use certificate/key-based authentication
 - Patch systems
 - Use least privilege and monitoring
 - Keep the protocol/design secure even if attackers know it

10. Risk Informed

- Security decisions should be based on risk, cost, and asset value
- Organisations should not spend more on protection than the asset worth

Question	Meaning
Does it make economic sense for the attacker?	If attacking costs more than the reward, attacker may not bother
Spending on security	Security controls cost money/resources
Value of asset	More valuable assets justify stronger protection

Information Security Management

- Information security management is about protecting information assets
- Information assets include
 - The information/data itself
 - The system that store, process or transmit the information

Security goal	Meaning	Simple example
Confidentiality	Only authorised people can access information	Only HR can view payroll data
Integrity	Information is accurate and not tampered with	Prevent unauthorised changes to marks or bank details
Availability	Information/systems are accessible when needed	Website stays online during business hours
Accountability / non-repudiation	Actions can be traced to the person/system responsible	Logs show who approved a transaction

Security Controls

Control	Simple explanation
Access control	Decide who can access what
Disaster recovery	Restore systems after failure or attack
Penetration testing	Test whether security controls can be bypassed
Monitoring/logging	Detect suspicious behaviour

Managing Cyber Risks

- Identifying what needs protection, understanding possible risks, and choosing controls to reduce those risks
- It is an ongoing process, not a one-time task

Step	Meaning	Simple example
Identify assets	Know what needs protection	Customer database, payment system, laptops
Identify and quantify risks	Find risks and estimate their impact/likelihood	Ransomware could stop business operations
Decide target state/maturity	Choose the level of security the organisation wants	Essential Eight maturity level
Develop policies and standards	Create rules for secure behaviour and systems	Password policy, BYOD policy
Compliance audit	Check whether rules and standards are followed	Audit checks if MFA is enabled
Metrics and reporting	Measure and report security status	Number of vulnerabilities fixed this month
Red/Blue Teaming	Test attack and defence capability	Red team attacks, blue team detects/responds
Vulnerability scans	Find known weaknesses	Scan servers for missing patches

What is risk?

- Risk happens when a threat can exploit a vulnerability and cause harm
 - Likelihood: how likely the bad event is
 - vulnerability: the weakness that can be exploited
 - impact: how serious the damage would be
- Risk = Threat + Vulnerability

Term	Meaning	Simple example
Threat	Something that can cause harm	Malware, attacker, storm, thief
Vulnerability	Weakness that can be exploited	Unpatched OS, weak password, no encryption
Risk	Possible harm caused by threat exploiting vulnerability	Data breach, system compromise, downtime

- Example

Threat	Vulnerability	Risk
Computer worm	Unpatched operating system	Compromised host

Threat	Vulnerability	Risk
Laptop theft	Unencrypted disk	Data breach
Storm	Underground data centre	Flooded data centre

How to Measure a Risk

Qualitative risk Analysis

- Low
- Medium
- High
- Extreme
- Function of IMPACT that bad thing happens, LIKELIHOOD of that bad thing
- $RISK = IMPACT \times LIKELIHOOD$

Quantitative risk analysis

- Measures risk using numbers and money values
- Help estimate the expected financial loss from a cyber risk

Term	Meaning	Formula / Example
Asset Value (AV)	The money value of the asset	Research data = \$1M
Exposure Factor (EF)	Percentage of asset loss if incident happens	50% loss = 0.5
Single Loss Expectancy (SLE)	Loss from one incident	$SLE = AV \times EF$
Annualised Rate of Occurrence (ARO)	How often it happens per year	Once every 2 years = 0.5
Annualised Loss Expectancy (ALE)	Expected loss per year	$ALE = SLE \times ARO$

Approaches to addressing risks

- 4 Choices
 - Accept

- Important to define acceptance criteria or “risk appetite” of an organisation
- Transfer
 - Buy insurance
 - Outsource
- Mitigate
 - Implement controls
- Avoid
 - Give up on that activity

Risk Mitigation

- Implement countermeasures to reduce likelihood or impact
- Controls

Type	Meaning	Simple example
Administrative	Rules, policies, procedures, training	Password policy, BYOD policy
Physical	Physical protection for people/buildings/devices	Locks, walls, CCTV
Technical	Technology-based protections	Firewall, MFA, secure configuration

- In general
 - Administrative / Physical / Technical
 - Administrative = policy, rule, approval, process, training
 - Physical = lock, door, camera, building security
 - Technical = software, system setting, security tool
 - Preventive / Detective / Corrective
 - Preventive = stops bad things before they happen
 - Detective = finds or alerts when something happens
 - Corrective = help fix or recover after something happens

Example	Control type	Control purpose
HR Manager must approve before user can access HR system	Administrative	Preventive
Enforcing minimum password length	Technical	Preventive
Intrusion Detection System (IDS)	Technical	Detective
Intrusion Prevention System (IPS)	Technical	Preventive
Antivirus software	Technical	Preventive / Detective
Developers must follow secure coding best practices	Administrative	Preventive
Patching systems with latest security patches	Technical	Preventive / Corrective
Security incident response plan	Administrative	Corrective
Data centre door must be locked	Physical	Preventive
Surveillance camera monitors entrance	Physical	Detective

Infosec Management Frameworks

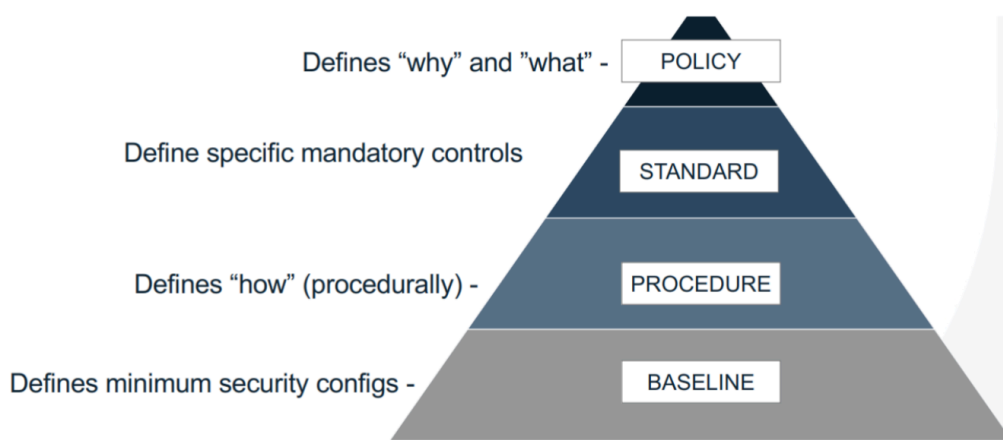
- Security frameworks and standards
- These frameworks and standards help organisations choose controls, manage risk, and improve security in a structured way

Framework / Standard	Main purpose	Simple explanation
ISO/IEC 27001	Security management certification	Organisation can be certified against it
ISO/IEC 27002	Security control guidance	Gives detailed advice on security controls
NIST CSF	Cybersecurity framework	Organises security practices into functions
CIS Controls	Practical security controls	List of best-practice controls to reduce common attacks
Essential Eight / ISM	Australian government guidance	Mitigation strategies and security guidance from ACSC

- If an organisation want to be certified against 270001
- There are requirements from the organisation

Component	Simple meaning
Scope	What systems/teams/locations the ISMS covers
Policies & objectives	Security rules and goals
Risk assessment methodology	How the organisation measures risk
Statement of Applicability	Which controls are selected and why
Risk treatment plan	How risks will be handled
Risk assessment report	Results of risk assessment
Roles & responsibilities	Who is responsible for security tasks
Inventory of assets	List of important systems/data/devices
Access control policy	Rules for who can access what
Incident management procedure	Steps for handling security incidents
Business continuity	Plan to keep operating during disruption
Legal/contractual requirements	Laws, regulations, and contracts the organisation must follow

Policy Framework



Level	Purpose	Simple example
Policy	Defines why and what	"All company data must be protected."

Level	Purpose	Simple example
Standard	Defines mandatory controls	"Passwords must be at least 12 characters."
Procedure	Defines how to do something	"Steps to reset a user password."
Baseline	Defines minimum secure configuration	"Firewall must deny inbound traffic by default."

Week 11 Law and Ethics

Law vs Ethics

- Something can be legal but still feel unethical
- Something can feel morally right but still be illegal

Term	Meaning	Simple example
Law	Formal rules made by government or authorities	Privacy Act, cybercrime laws
Ethics	Personal/professional judgement about right and wrong	Whether monitoring users is fair or respectful

- Law does not always equal right, and ethically right does not always mean legal

Question	Legal issue?	Ethical issue?	Why
Can university monitor student internet activity?	Yes	Yes	It depends on policy, consent, privacy, and purpose
Can Facebook collect/sell personal information?	Yes	Yes	May be allowed by terms, but raises privacy concerns
Can Google sell targeted ads?	Yes	Yes	Legal with consent, but ethical concerns about tracking
Should university block racist websites?	Maybe	Yes	Balances safety, free speech, and acceptable use

Some keywords

Keyword	Simple meaning	Example
Privacy	Right not to be unnecessarily observed	Users do not want all browsing activity watched
Freedom of speech	Right to express thoughts/opinions by speaking	Posting or saying political opinions
Freedom of expression	Broader than speech; includes writing, art, online posts	Memes, images, videos, blogs
Surveillance and monitoring	Watching or recording activity	University/network logs, CCTV, internet monitoring
Internet laws	Rules for online behaviour and services	Data protection, online content rules
Cybercrime laws	Laws against hacking, malware, unauthorised access	Illegal access to someone's account
Surveillance laws	Rules controlling when monitoring is allowed	Government or workplace monitoring limits

- Cyber law questions often do not have simple yes/no answers
- The answer depends on the situation, responsibility, intent, jurisdiction and relevant laws

Example	What issue it raises
Your infected computer joins a DDoS attack	Are you responsible if your machine was compromised?
You lend your computer and coworker steals files	Are you responsible for allowing access to the machine?
You release encryption software open-source	Could it be illegal in another country or under export/security laws?

- It depends
 - Different countries have different laws
 - More than one law may apply
 - Many laws were not originally written for modern IT problems
 - Courts may need previous cases to decide how the law applies
 - Law comes from both
 - legislation: written laws

- precedent: previous court decisions

Category of Laws

- Cybersecurity is not covered by only one law. Different laws apply depending on the issue: privacy, hacking, spam, surveillance, data breaches, copyright, etc

Category	What it protects/regulates	Example
Privacy	Personal information collection/use	Privacy Act, GDPR
Crime and terrorism prevention	Hacking, fraud, cybercrime, terrorism-related activity	Cybercrime Act
Information security requirements	Organisations must protect information reasonably	ISM, security obligations
Market/economic integrity	Business reporting and governance	Sarbanes-Oxley Act
Data breach reporting	Organisations must report serious data breaches	Notifiable Data Breaches scheme
Intellectual property	Copyrighted works, software, media	Copyright Act, DMCA

Australian Federal Cyber-related laws

Law / scheme	Simple meaning
Australian Privacy Principles / Privacy Act	Controls how personal information is collected, used, stored, and disclosed
Cybercrime Act	Covers unlawful hacking, computer fraud, data theft, and unauthorised access
Spam Act	Regulates commercial emails and spam messages
Telecommunications Interception and Access Act	Regulates interception/access to communications
Data Retention laws	Requires ISPs/CSPs to keep certain metadata
Notifiable Data Breaches scheme	Requires eligible organisations to report serious data breaches
Copyright Act	Protects copyrighted content and intellectual property

Industry-specific Regulations

- Different industries have different cybersecurity and compliance requirements
- The rules depend on the type of organisation and the kind of data they handle

Industry	Regulation / guidance	Simple meaning
Banking and finance	APRA	Financial organisations have specific security/risk requirements
Federal government	ISM, AGPSF	Government agencies follow government security frameworks
Healthcare providers	RACGP standards	Health providers must protect patient and clinical information
Research	NHMRC research conduct code	Research data must be handled responsibly
ISPs and telecoms	ACMA, telecommunications laws	Telecom providers have rules around communications and interception
Credit card	PCI DSS	Organisations handling card payments must protect card data

Reporting

- Main idea
 - Legal reporting obligation after a cyber incident
 - Depending on the situation, organisations may be required to report information to different parties

Party	When it may be required
Police / law enforcement	If there is cybercrime, fraud, extortion, or illegal access
Affected individuals	If personal data is compromised or leaked
Investors / shareholders	If the incident may affect a public company's value or operations
Regulators	If privacy, finance, health, or telecom laws require reporting

- Some laws require disclosure

- Some laws restrict disclosure

Security flaw reporting

- Reporting security flaws can be legally sensitive
- If done responsibly, it may help improve security
- If done carelessly, it may expose systems to attack or violate laws/policies

Other Australian laws

Law	Simple meaning
ASIO Act	Defines ASIO's role and powers
Intelligence Services Act	Gives powers/functions to intelligence agencies such as ASIO, ASD, ASIS
Criminal Code Act	Covers crimes, including internet-based crimes
Electronic Transactions Act	Supports legal use of electronic transactions/e-commerce
National Security Information Act	Controls disclosure of sensitive national security information in legal proceedings

International Laws

- Convention Cybercrime (Budapest Convention) 2001
 - One country's laws may not be enough when attacker, victim, servers, and data are in different countries
 - Although it helps countries cooperate on cybercrime investigation
 - Cover issues like hacking, computer fraud, illegal access, and evidence sharing
- Then what will happen when the cyberattacks target hospitals, power grids, government or civilians.
 - Normal cybercrime laws may not be enough
 - Countries may refuse to cooperate
 - Attacker may be a state actor, not a normal criminal

Legal Considerations in Pen Testing

- Penetration testing must be authorised, legal, and documented
- Even if the purpose is security testing, it can become illegal if it is done without permission or outside the agreed scope

Consideration	Simple meaning	Example
Compliance	The test must follow relevant laws and regulations	Privacy law, data protection, intellectual property law
Liability	The tester/organisation may be responsible if testing causes damage	Test crashes a server or disrupts real users
Documentation	The test must be clearly recorded and agreed	Scope, methods, permission, results

- Important points
 - Get written permission before testing
 - Define the scope clearly: What systems can and cannot be tested
 - Avoid accessing, copying, or exposing personal/sensitive data unless authorised
 - Keep evidence and results documented
 - Report findings responsibly

Point	Simple meaning
Law is complicated	Cyber issues may involve many legal areas
Many laws may apply	Privacy, cybercrime, surveillance, contracts, IP laws, etc.
Different jurisdictions	Laws differ between countries/states
Act reasonably	Individuals should act carefully, honestly, and in good faith
Get legal guidance	Companies should ask lawyers when legal risk is involved

Ethics

- Ethics is about deciding what is right or wrong, not about what is legal or illegal

- In cyber, ethical issues often appear when security conflicts with privacy, freedom, fairness or user rights

Ethical Reasoning

- Ethical reasoning helps people to decide whether an action is right or wrong
- Justify decisions, especially when there is no clear answer

Teleology

- Base on consequences of the decision
 - Decide on actions based on the consequences
 - Think about the state of the world, following an act
 - Evaluate the state of the world
 - Act to maximise the value of the state of the world
 - Consequences may be uncertain
 - Value of a state may be hard to determine

Deontology

- Judges the action by whether it follows duties or principles
- Not focused mainly on consequences: Even if the result is useful, the action may still be wrong
- Duties can conflict: You may have more than one responsibility at the same time

Ross' list of duties

- Ross' list gives common ethical duties, such as truthfulness, fairness, helping others, avoiding harm, and self-improvement
- Cybersecurity decisions often involve conflicting duties
 - Such as security monitoring may support beneficence, but conflict with privacy and non-maleficence
- Ethical decisions require explaining which duty matters most in the situation

Duty	Simple meaning	Cybersecurity example
Fidelity	Keep promises and be truthful	Follow the agreed pen-test scope
Reparation	Fix or compensate for harm caused	Report and help fix damage caused by testing
Gratitude	Recognise help/services received	Respect responsible disclosure from researchers
Justice	Treat people fairly	Apply security rules equally, not selectively
Beneficence	Help others	Protect users from attacks and data breaches
Non-maleficence	Do not harm others	Do not expose user data unnecessarily
Self-improvement	Improve your own ability/knowledge	Keep learning secure practices and legal duties

Employment

- In cybersecurity jobs, employer may ask you to do something that feels uncomfortable or different from what you would personally choose

View	What it focuses on	Example
Teleological	Consequences of the decision	Refusing may risk your job or promotion
Deontological	Duties and responsibilities	You may feel duty to keep promises to employer

- Example: Employer asks. you to monitor employee internet activity
 - Teleological: You may consider the consequences, such as protecting the company, but also harming employee privacy
 - Deontological: May consider duties, such as loyalty to employer, honesty, privacy, and avoiding harm
- Security work can create conflict between personal ethics and employer instructions
- **Teleological reasoning considers consequences such as job loss, promotion, harm and benefits**

- **Deontological reasoning considers duties such as loyalty,, promise-keeping, honesty, and avoiding harm**
- Employees should act reasonably, follow law/policy, and seek guidance when instructions seem unethical or illegal

Ethics with or against the law

- Ethics and law do not always match
- Sometimes an action can be
 - Legal and ethical
 - legal but unethical
 - illegal but personally seen as ethical

Situation	Simple meaning	Example
Ethics aligns with law	The legal action also feels morally right	Reporting a serious data breach
Ethical but illegal	Someone believes the action is right, but it breaks the law	Unauthorised hacking to expose a flaw
Legal but unethical	The law allows it, but it feels morally wrong	Collecting excessive user data through unclear consent
Civil disobedience	Breaking a law on moral grounds, while accepting legal consequences	Protest actions like Gandhi or MLK
Resistance to the law	Actively opposing a law considered unjust	Refusing to follow a law seen as harmful
Follow law while trying to change it	Obey the law but campaign for reform	Lobbying for better privacy laws

Example:

- ❑ A healthcare facility uses an Enterprise Resource Planning (ERP) to manage different aspects of the facility, and the IT admin of the healthcare finds a new vulnerability in the ERP that, to fix, requires immediate patching of the system.
- ❑ However, that may take up to 12 hours, and the ERP will not be operating until the patching is complete.
- ❑ The IT admin knows this will affect the healthcare facility's in-patient facility and treatments, and, therefore, decides to update the software patch at night when there are less patients and no surgical procedures going on.
- ❑ However, it violates the [General Data Protection Regulation \(GDPR\) Article 32](#), which states that systems must be patched as soon as the updates are provided, or vulnerabilities are identified.



- Security vs availability/patient safety
- Immediate patching may satisfy compliance but disrupt critical healthcare operations
- Delayed patching may reduce patient impact but leaves the system vulnerable for longer
- Ethical decision-making requires balancing legal duties, security risks, and real-world harm
- A good approach would document the decision, assess the risk, apply temporary control, and patch at the safest possible time

GDPR → General Data Protection Regulation

- EU data protection law
- Protects people's personal data and gives individuals rights over how their data is collected, used, stored and shared
- It also affect Australian organisations

Right	Simple meaning
Notification of breach	People should be informed if their data is seriously compromised
Erasure	People can request deletion of their personal data
Portability	People can request their data in a usable format and move it elsewhere
Restrict data processing	People can limit how their data is used
Rectification	People can ask for incorrect data to be corrected

Right	Simple meaning
Anonymity	Data should not identify people when identification is not needed
Access	People can ask what data an organisation holds about them
Consent	Organisations often need clear permission to collect/use data

Practical roles and processes created/required by GDPR

- Tell organisations who is responsible and what process organisation should follow when handling personal data

Term	Meaning	Simple example
Data Protection Officer	Person responsible for advising/monitoring GDPR compliance	Checks if hospital data handling follows privacy rules
Data Controller	Organisation/person deciding why and how data is used	Hospital decides to collect patient records
Data Processor	Organisation/person processing data for the controller	Cloud provider stores patient records for the hospital
Data Protection Impact Assessment	Risk assessment for privacy before high-risk data processing	Assess risk before using a new patient tracking system
Privacy by design	Build privacy protection into the system from the start	Collect only needed data, use encryption, limit access

GDPR Challenges

- GDPR compliance is difficult because organisations must know
 - What personal data they have
 - Where it is stored
 - Why it is collected
 - How it is used
- This is hard because the data is spread across many systems, departments, cloud services, backups, and third-party tools.

Challenge	Simple explanation
Identification of diverse technology	Organisations use many different systems, apps, databases, cloud services, and devices
Identification of data	They must know what personal data exists and where it is stored
Why data was collected	Organisations need a valid reason/purpose for collecting personal data
How data was collected	They must understand the collection method, such as forms, apps, cookies, or third parties
How data was used	They must track whether the data is used for the original purpose or something else
How long data was used	They must know retention periods and avoid keeping data longer than necessary

Ethical Consideration in Pen Testing

- Pen testing must be done in a way that is authorised, honest, confidential and responsible
- Even if the goal is to improve security, unethical testing can still cause harm

Consideration	Simple meaning	Example
Authorisation	Get clear permission before testing	Written approval and agreed scope
Transparency	Be honest about methods/tools used	Tell client what type of testing will be done
Confidentiality	Protect data found during testing	Do not leak passwords, customer data, or vulnerabilities
Responsibility	Avoid unnecessary harm	Do not crash systems or disrupt users